


# PENTEST+ ASSIGNMENT

EDUV12936584

ITVTA0-33

Formative Assessment

EDUV12936584

ABSTRACT

This project will conduct Penetration testing, Setting up a Virtual Lab, and analyse security finds as well as include reconnaissance vulnerability identification.

Branny Aurthur Branfield

Penetration testing

# Question 1

1.1 The Microsoft Security incident in the article is as follows: Authorisation Misconfiguration in Azure AD allowing external parties access to internal applications which may have been incorrectly configured multi-tenant applications lacking proper authorisation checks resulting to access towards resources from unregistered clients.

In which they are addressed by additional security measures like additional authorisation checks, access tokens requirement, Azure App services Authentication option for added security and a Guidance on securing Multi-tenant application with Azure AD for Admins and Developer which include review and update, Conditional access policies, Monitoring Sign-in logs, recommended checks and use of (MSAL) Microsoft Authentication Liabrary.

This relates to the Security issues identified in Eduvos student registration system and addresses it with the issues involving student successful log in using valid credentials with a flaw resulting in being

able to access confidential Finance department salary records due to missing authorisation controls that are discussed in the Microsoft Security Response Center article article.

- With Microsoft addressing misconfiguration in Azure AD allowing external parties access to internal applications.
- With issues needing to be resolved with additional security measures.

1.2 Authentication is the process of verifying who a user is and Authorization is the determination of what resources or actions a user can access.

With Authentication confirming a user's true identity of who they are with users providing credential like username and Password

And Authorisation granting permissions and access levels to a verified user after determining what they are allowed to access on the system.(User role checks, Rule and Security clearance.)

In Eduvos Students were able to log in and able to access the Finance department's salary records in which they should not have been able to.

Which indicates functionality of Authentication and a flaw in Authorization.

Students ability to access finance department is a sign of improper Authorisation.

Students ability to log in Credentials is a sign of Proper Authentication.

1.3 Proper Authorisation is essential for protecting sensitive organisational data as it prevents data breaches, ensuring legal compliance, and maintaining data integrity by restricting access only to verified users who need the information for specific roles.

Meaning without proper authorisation the is a potential risk of users being granted access beyond their authorised roles in institutions like Eduvos which may cause data breaches, weakened legal compliance and neglected data integrity allowing sensitive data to be access by a undeserving user

such as a student access Finance department records.

1.4 Penetration testing could have helped Eduvos identify and resolve authorisation misconfigurations through active exploitation, verification, remediation and by simulating unauthorized access attempts, specifically finding broken access controls like students viewing finance records.

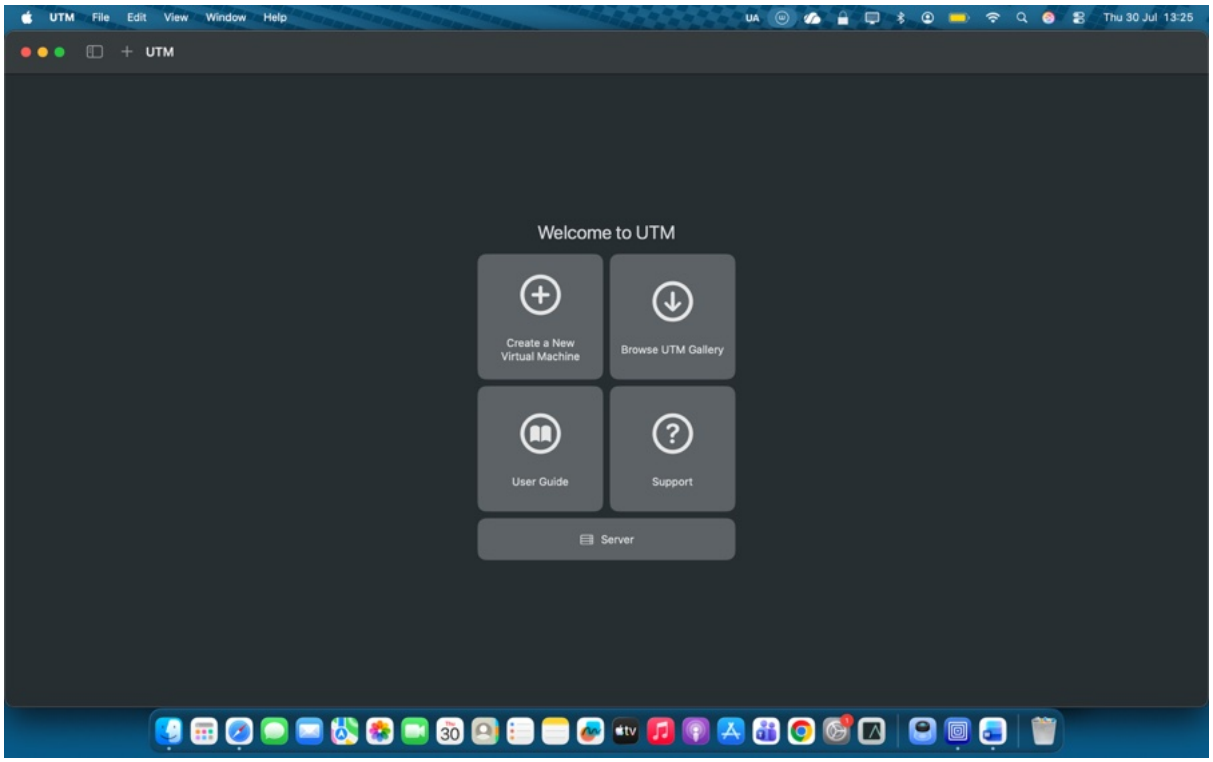
Usable Pentest activities include:

- Force Browsing(Path Transersal) Testing login with low-privilege student account.
- IDOR(Insecure Direct Object Reference) Test numerical IDs change in web request logged in as Student. checking if system lets user view other peoples private data files.
- Session and Role Manipulation(Privilege Escalation) Tester intercepting network traffic using proxy tools while logged in as student and changing role parameters in cookies, JSON token, or hidden form field to test if the backend blindly trust clients-side inputs.

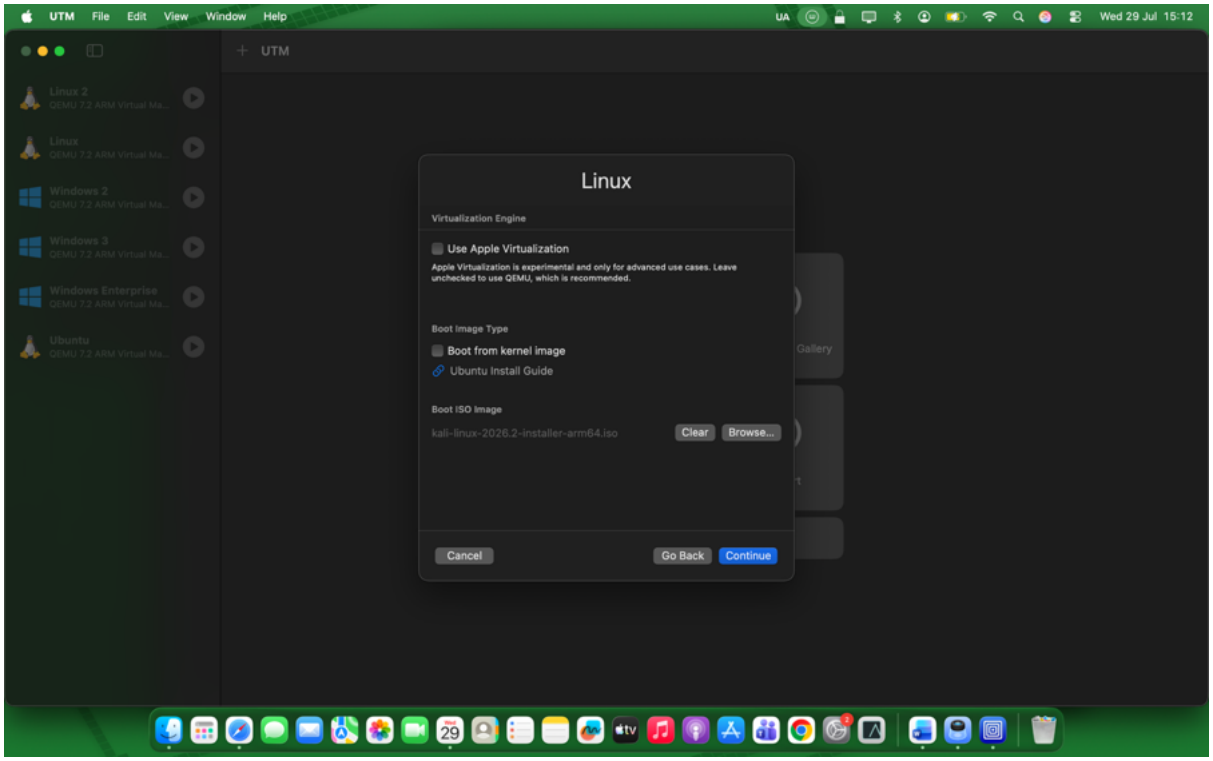
Resloving Vulnerability with Implement Role-Based Access Control(R-BAC) and Deny by Default.

# Question 2

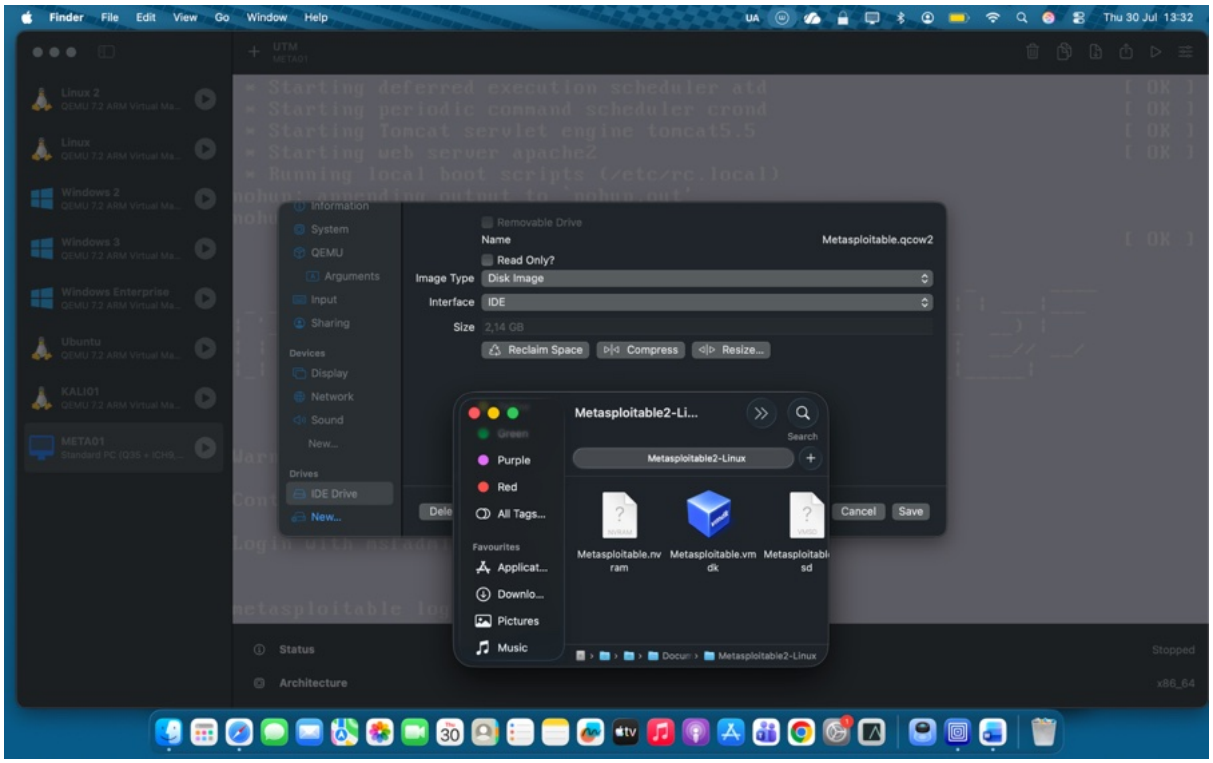
Note: The Virtualization platform begin used is “UTM” due to VMware and VirtualBox malfunction with Mac ARM64 Silicon M chip.



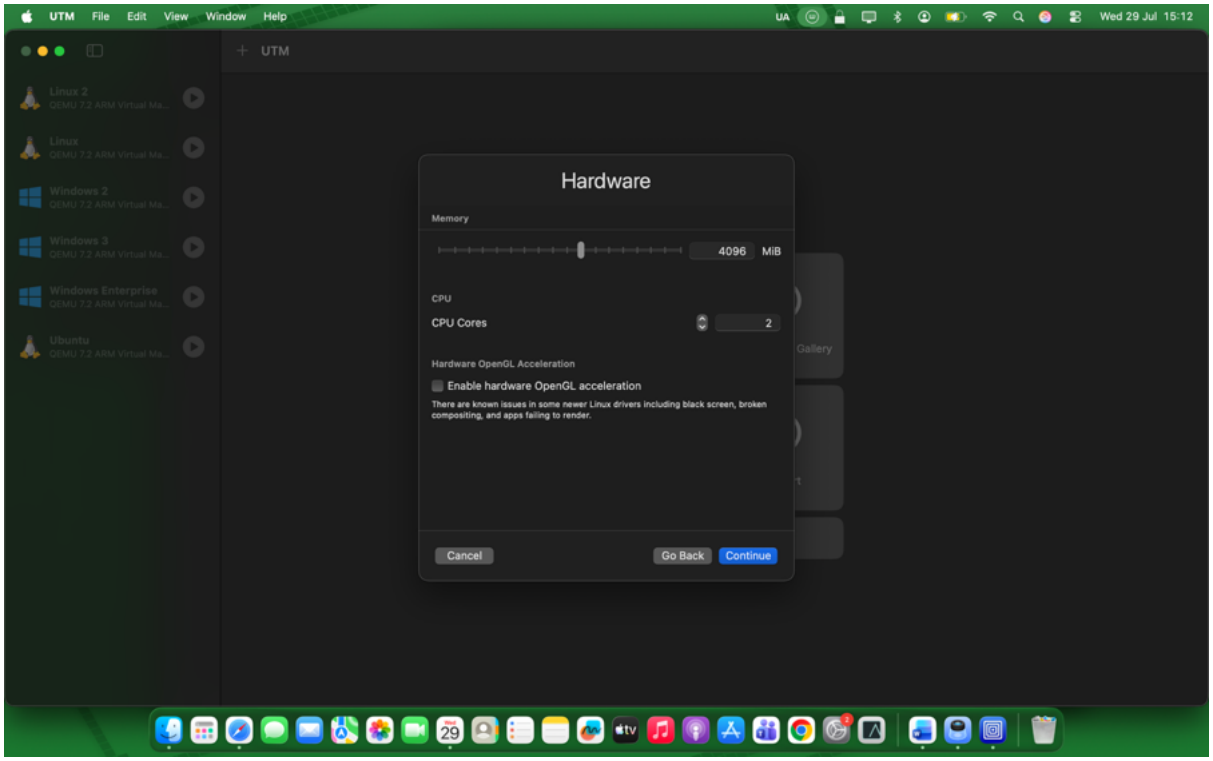

UTM Virtualization platform.



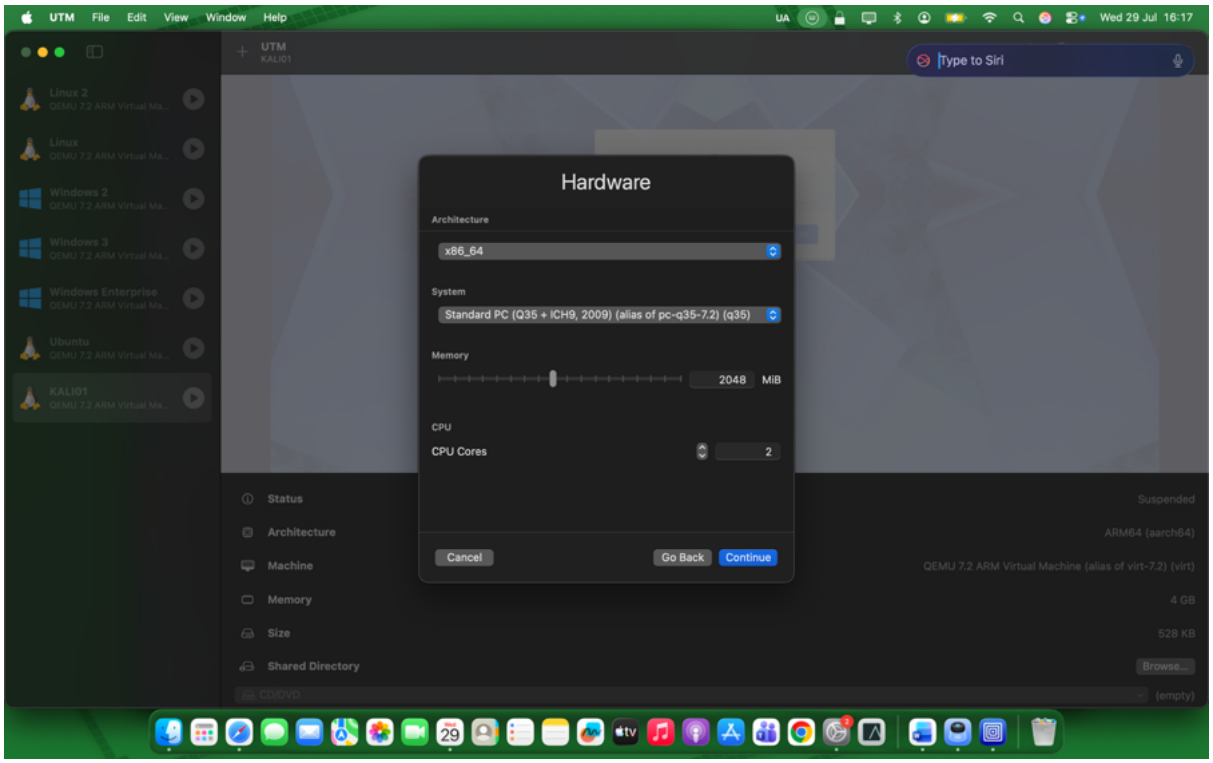

Iso image for Kali Linux.



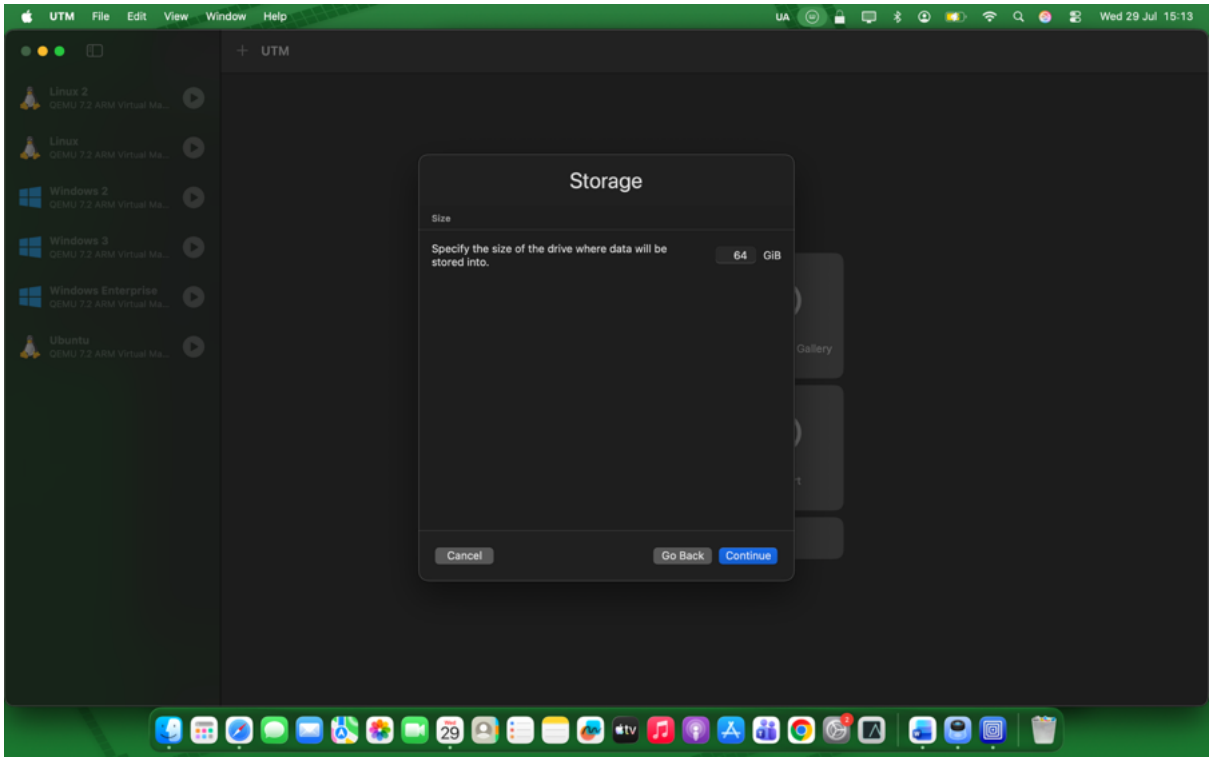

IDE drive for Metasploitable 2.



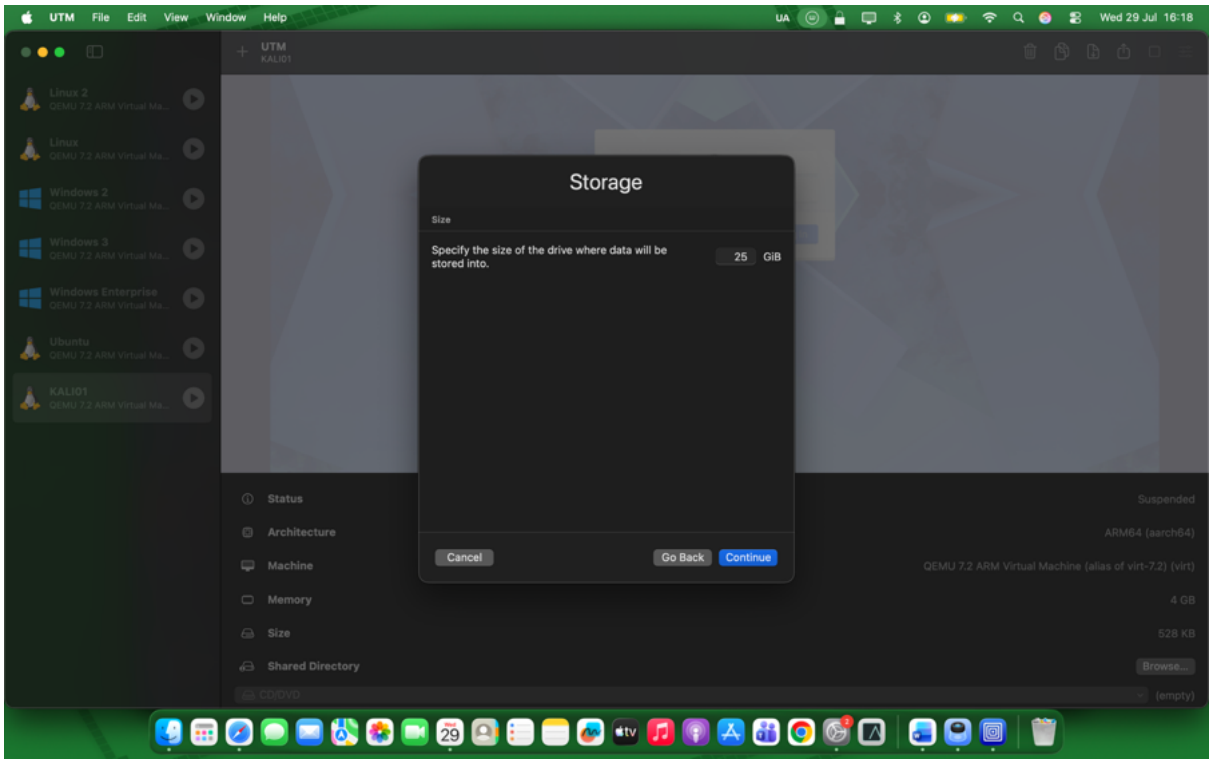

RAM and core CPU configuration for Kali Linux.



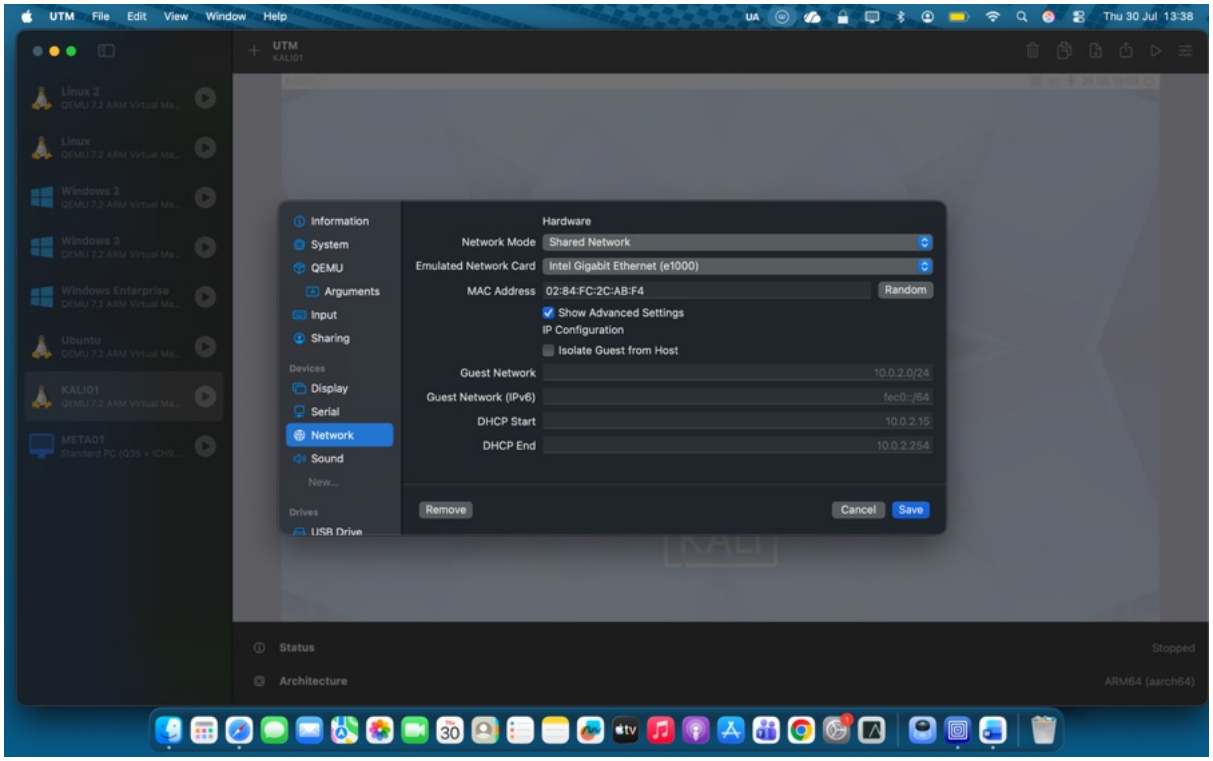

RAM and CPU configuration for Metasploitable 2.



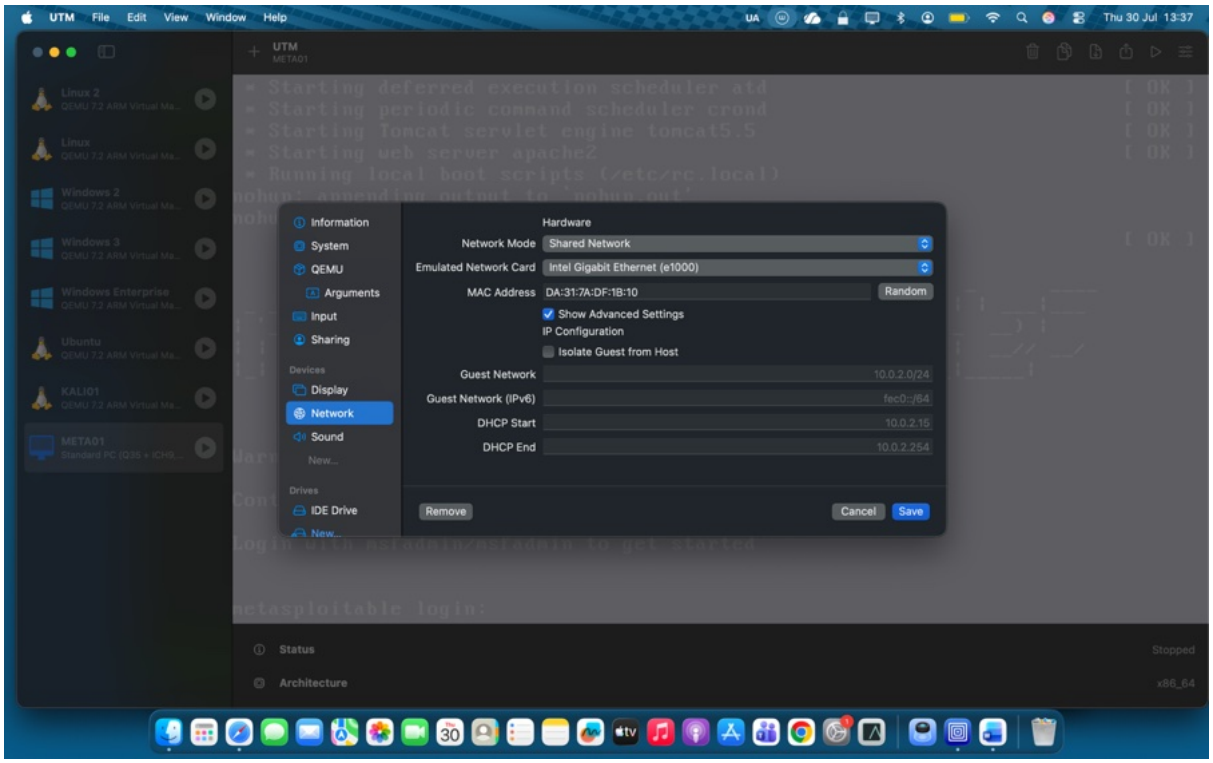

Hard Disk Configuration for Kali Linux.



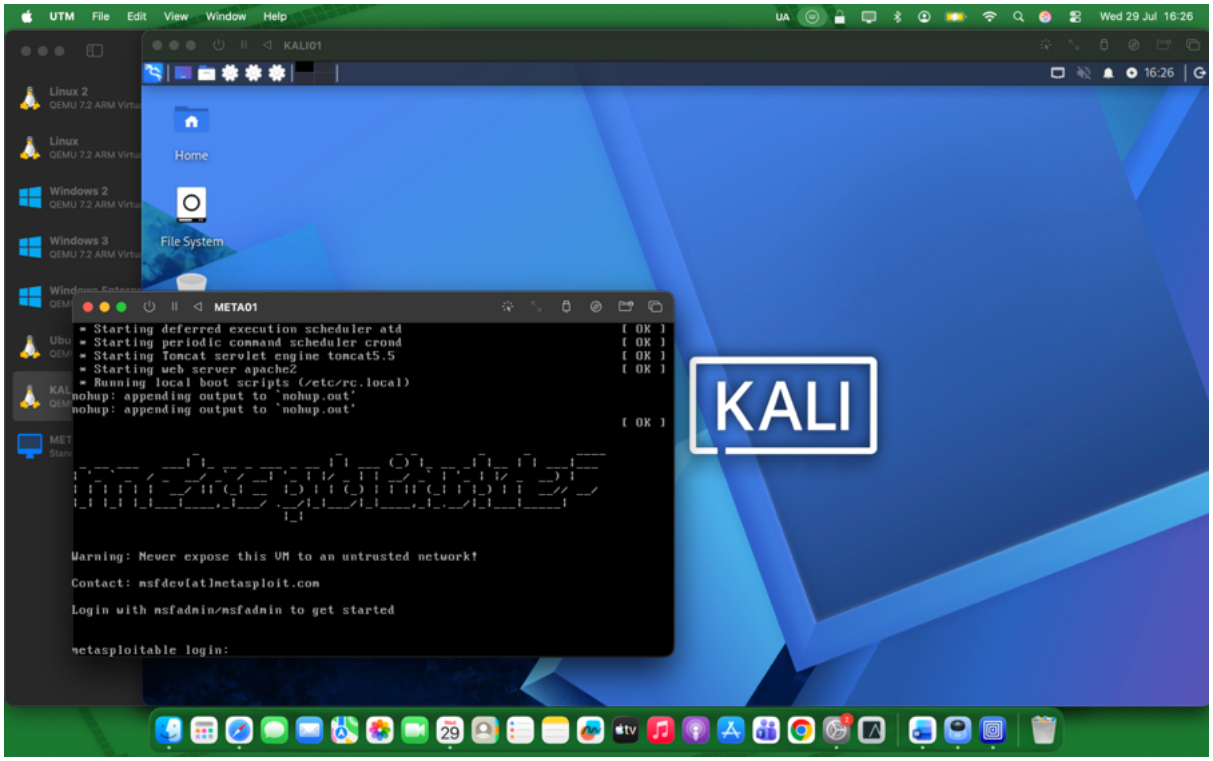

Hard Disk Configuration for Metasploitable 2.



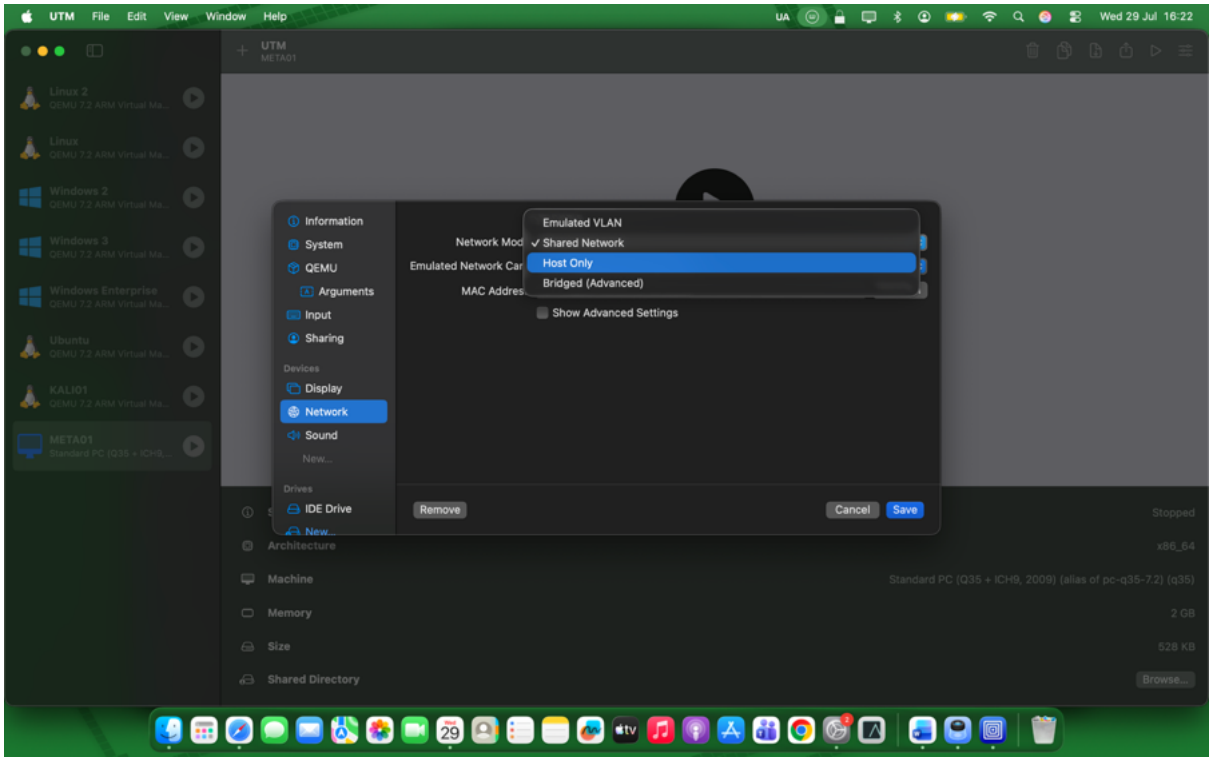

Default Network Adapter configuration for Kali Linux.



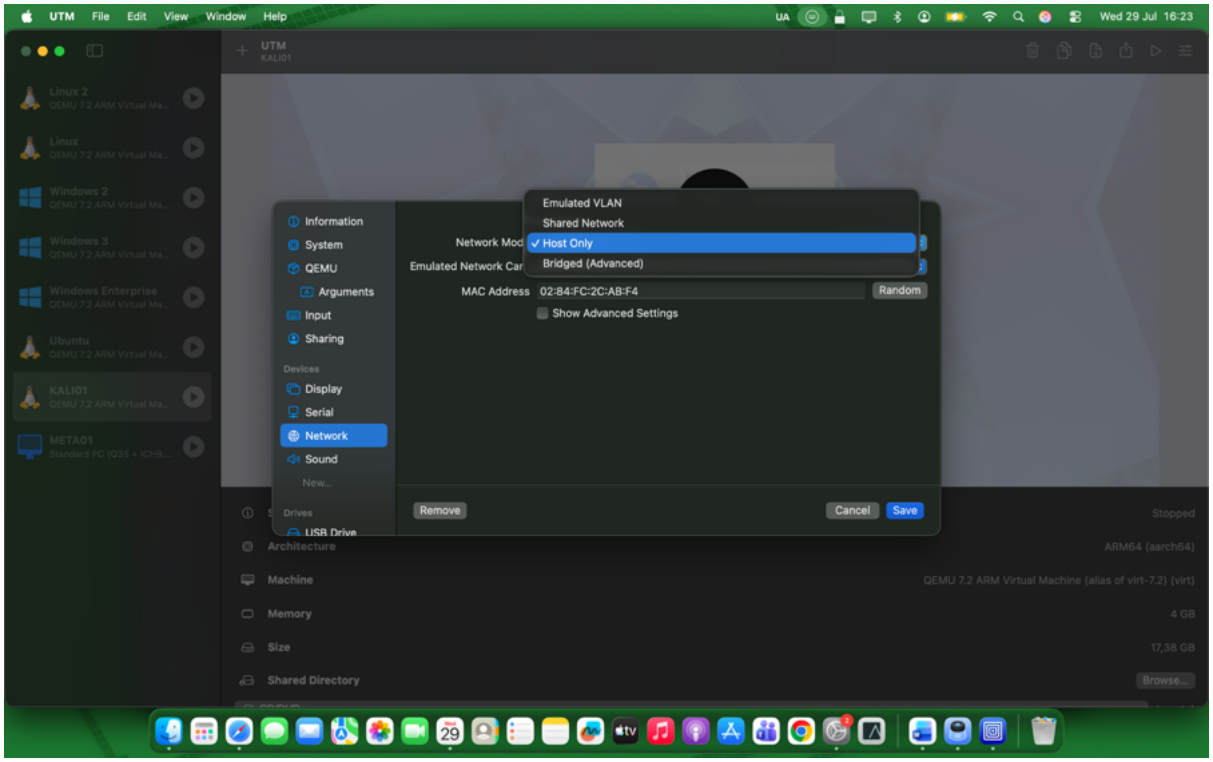

Default Network Adapter configuration for Metasploitable 2.



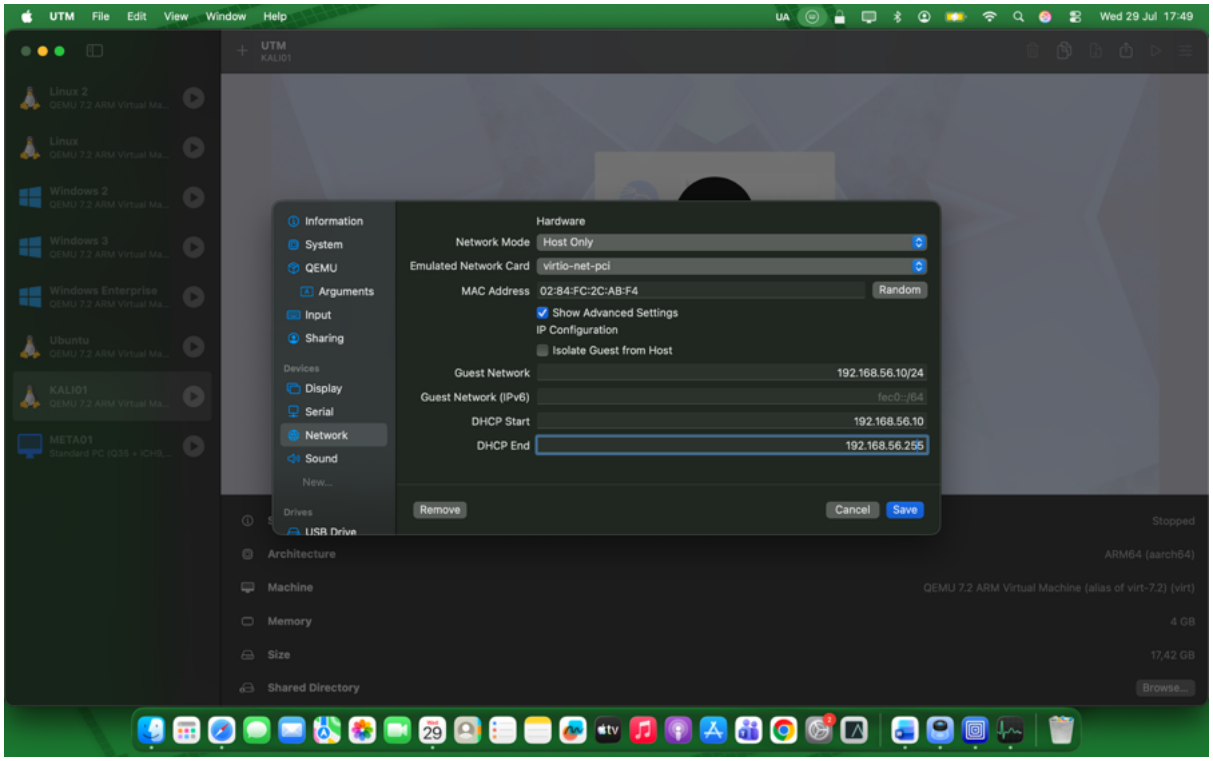

Two Virtual Machines Kali Linux and Metasploitable 2 Successfully Booted Running.



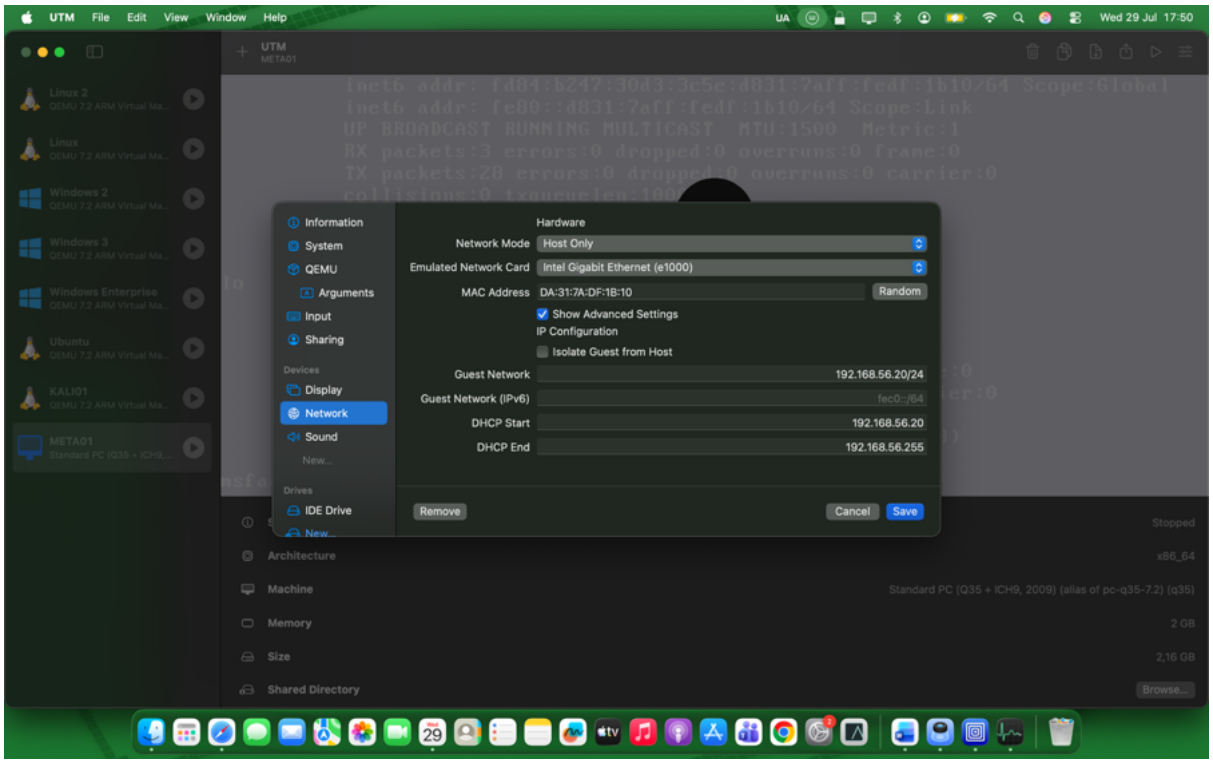

Assigning Host-Only Network Settings to Metasploitable 2.




Assigning Host-Only Network Settings to Kali Linux.

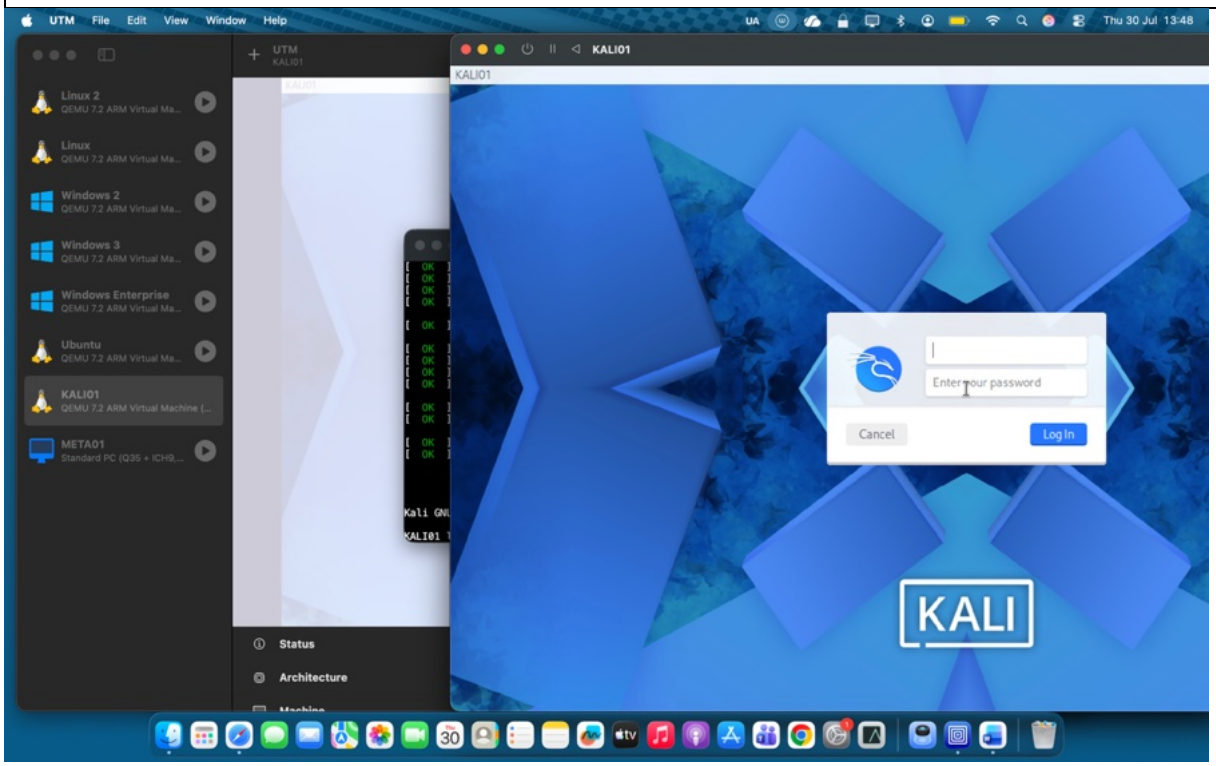


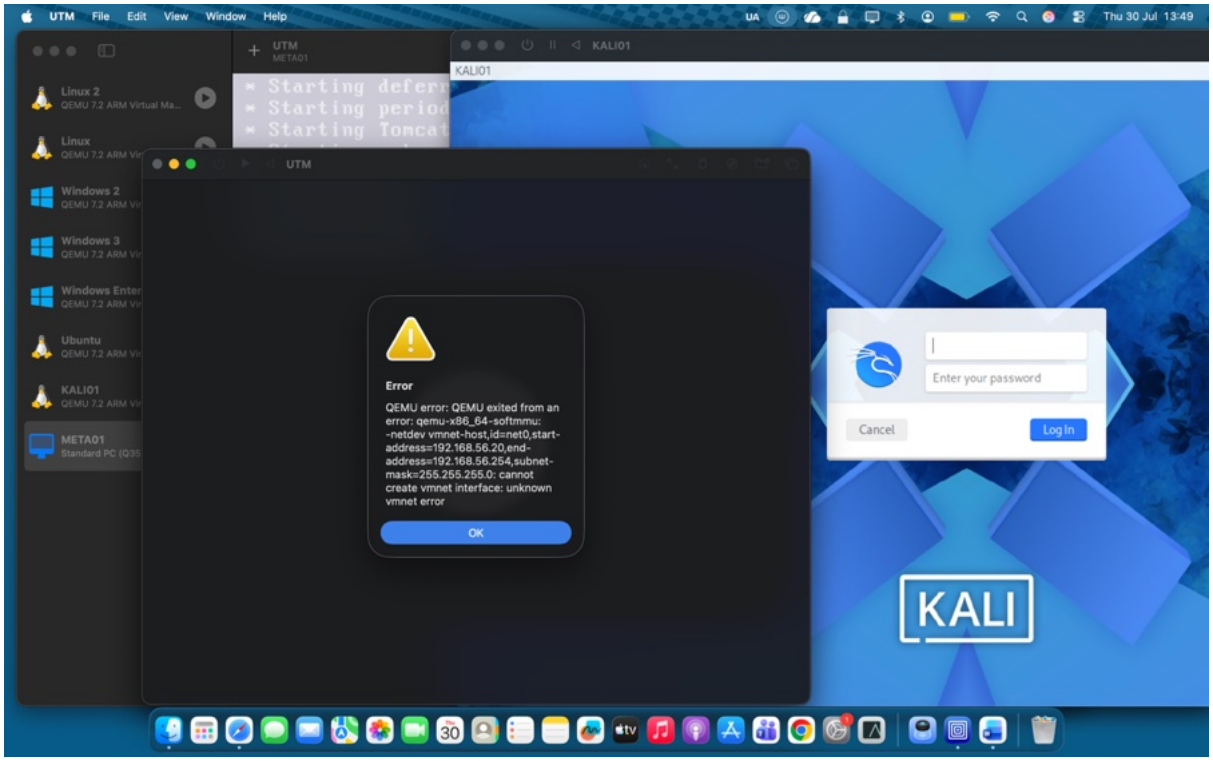

Assign IP Address Scheme 192.168.56.10/24 for Kali Linux



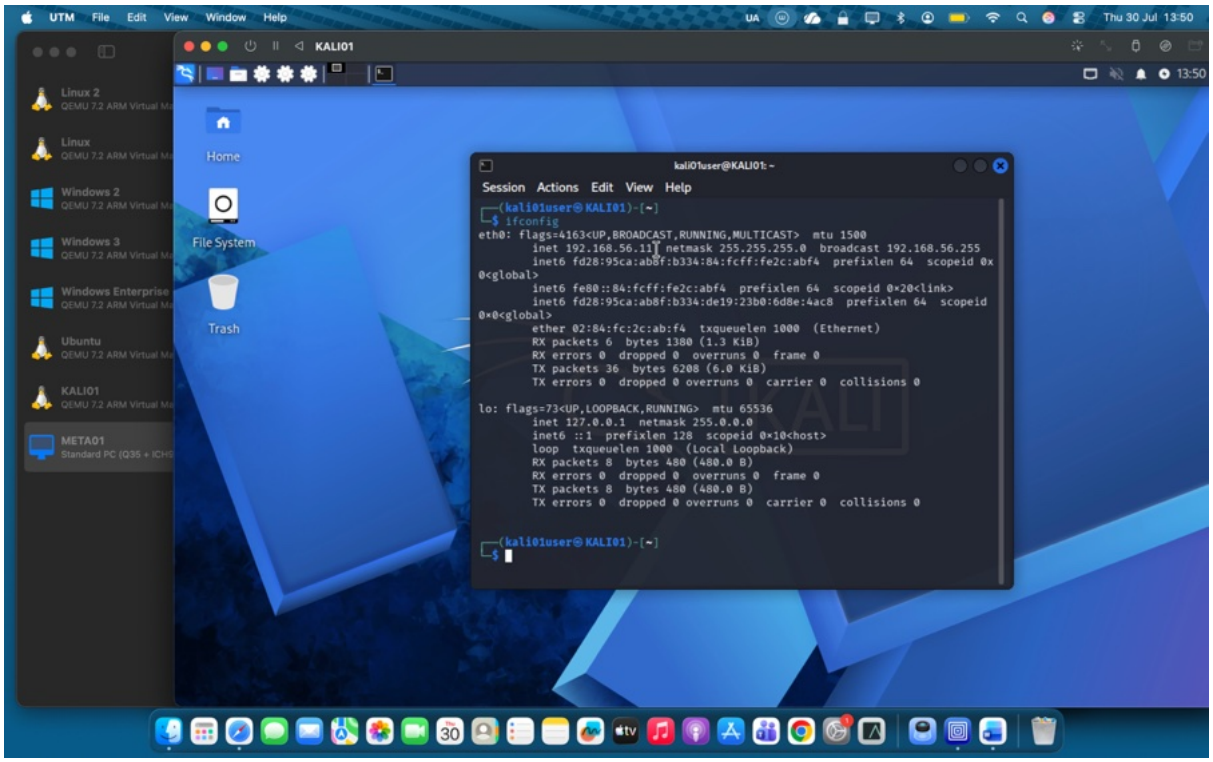

Assign IP Address Scheme 192.168.56.20/24 for Metasploitable 2

NOTE: After may attempts and research I have come to a conclusion that Host-Only and assigned IP Address Scheme on UTM is possible but introduces flaws preventing the two VM's from running at the same time.

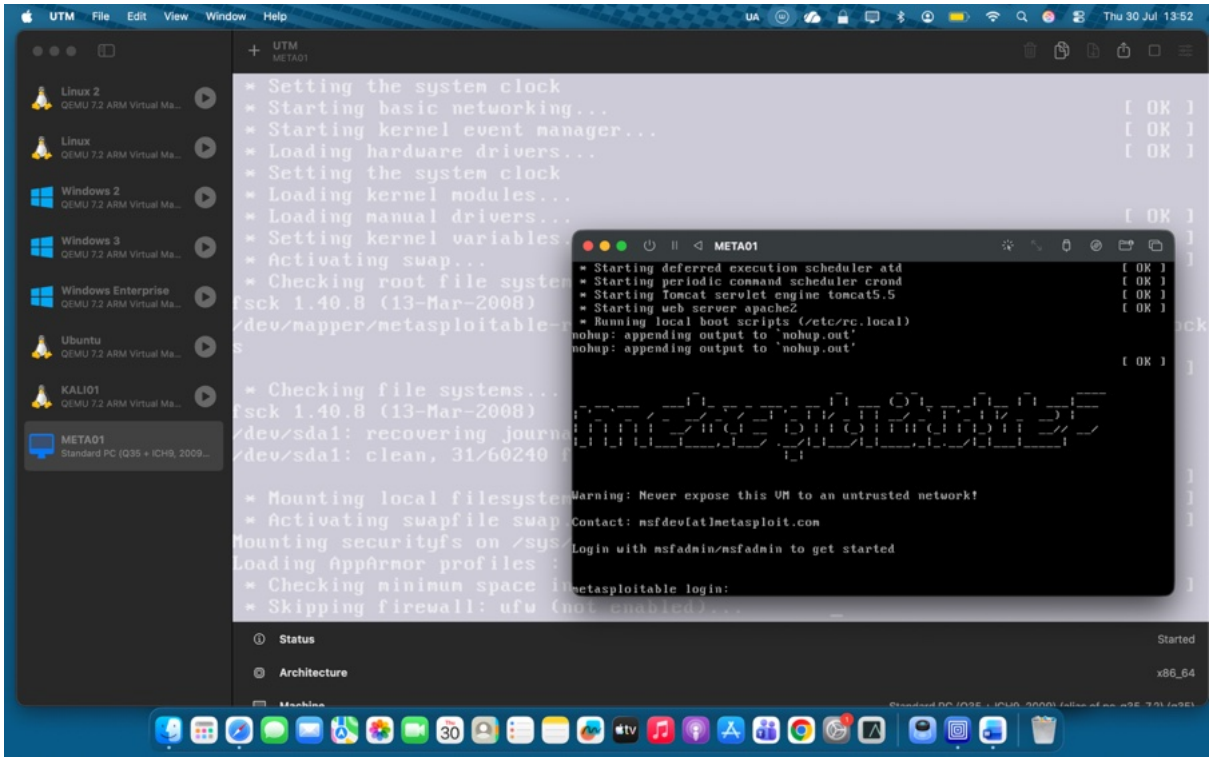


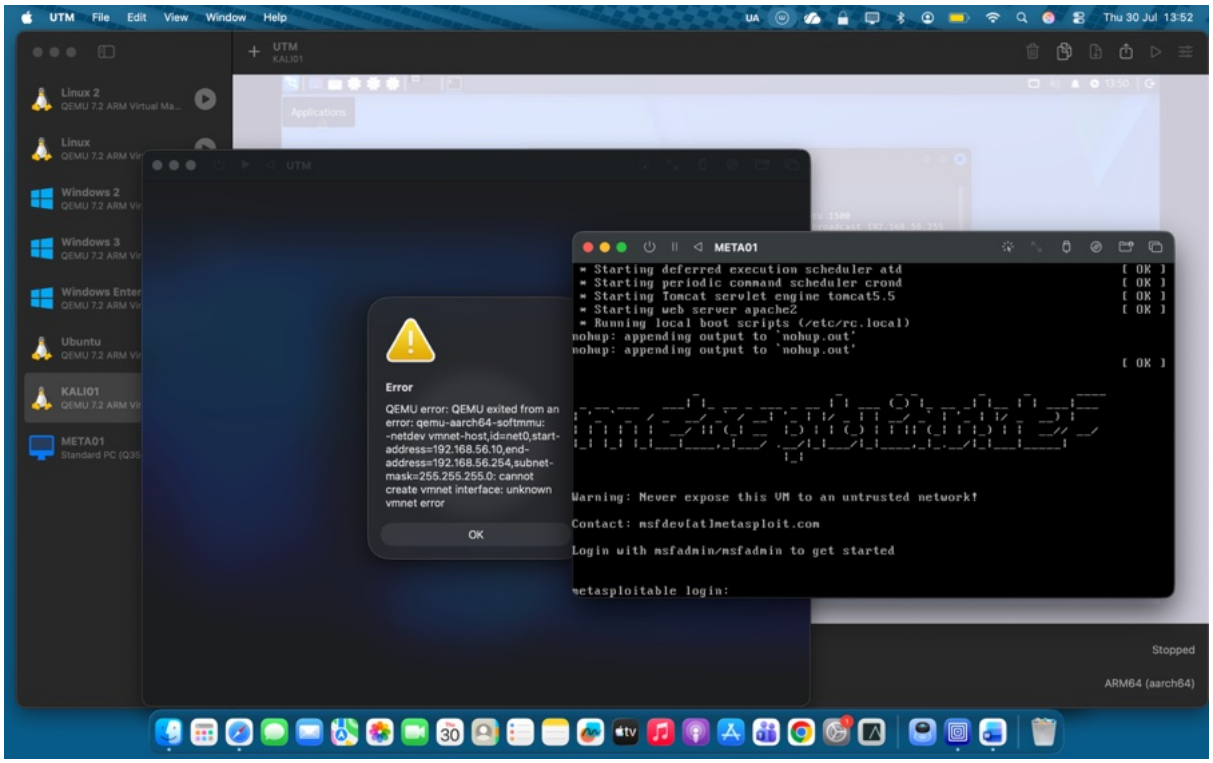



Evidences of the flaw mentioned in the note with Metasploitable 2 not running while Kali Linux is running.

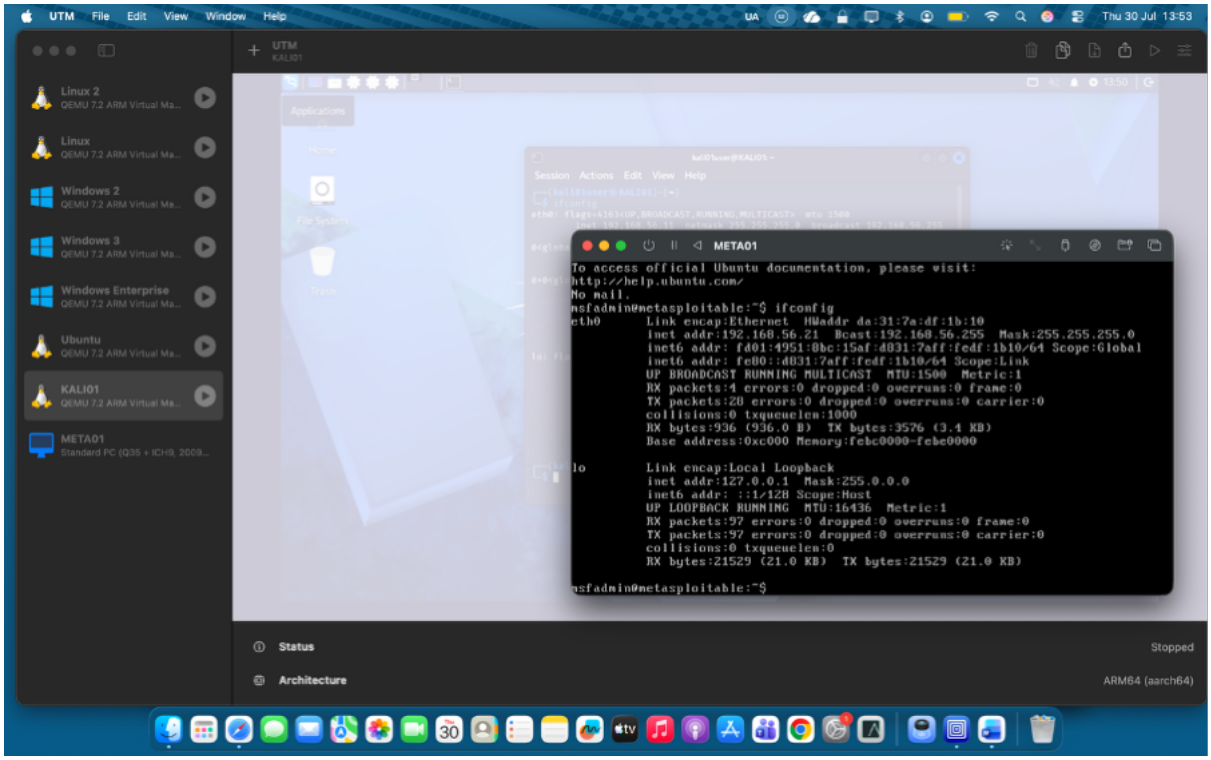



Evidences that IP Addressing Scheme 192.168.56.10/24 is functional for Kali Linux.



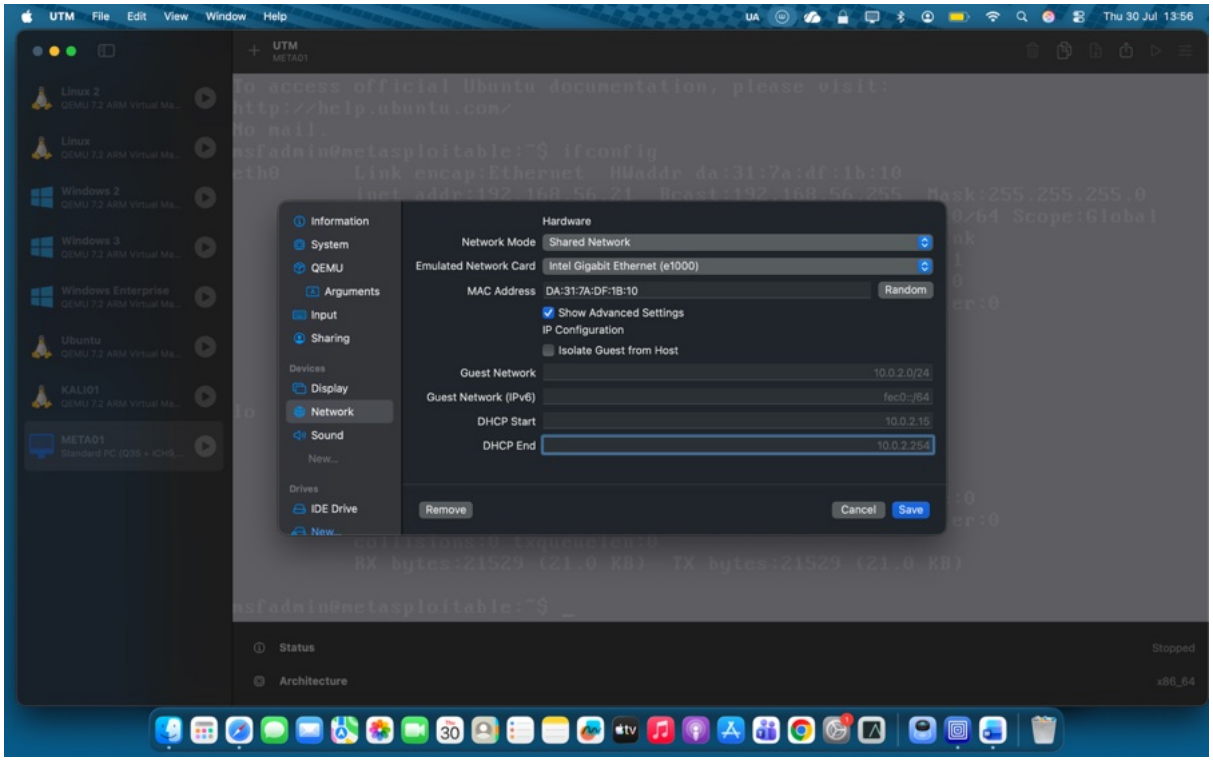




Evidences of the flaw mentioned in the note with Kali Linux not running while Metasploitable 2 is running.

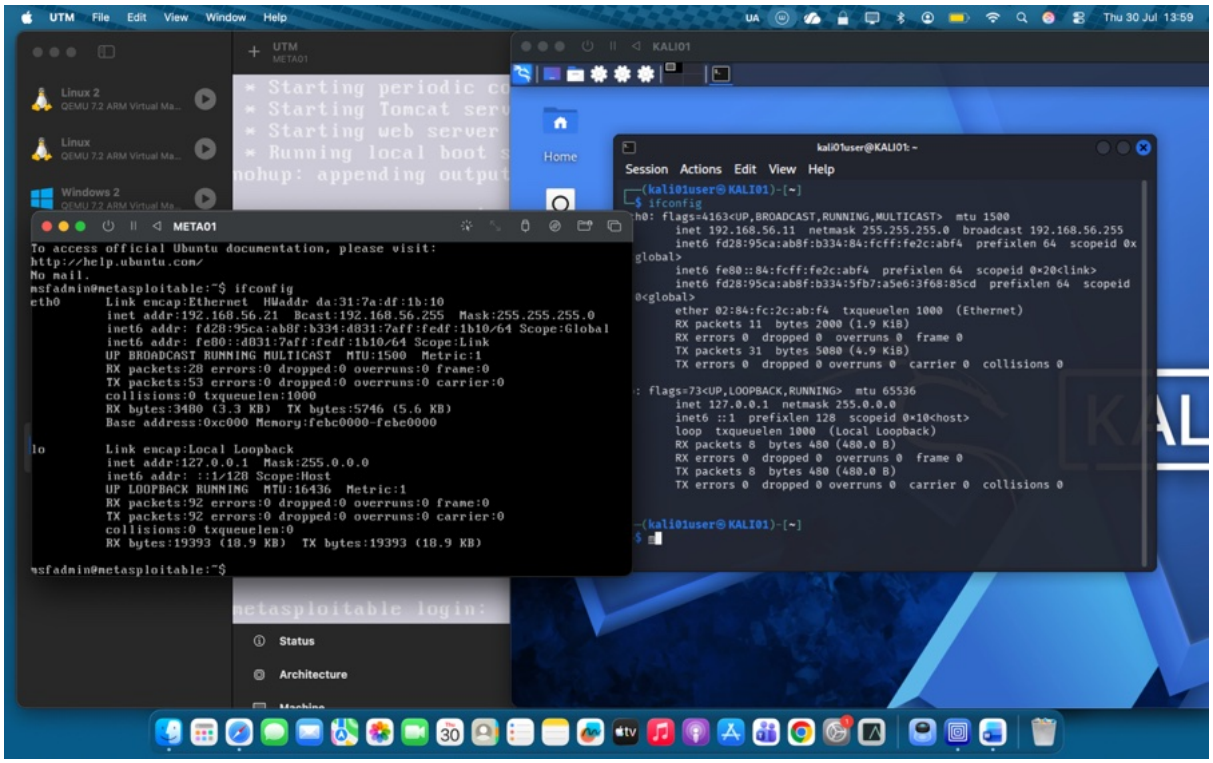



Evidences that IP Addressing Scheme 192.168.56.20/24 is functional for Metasploitable 2.

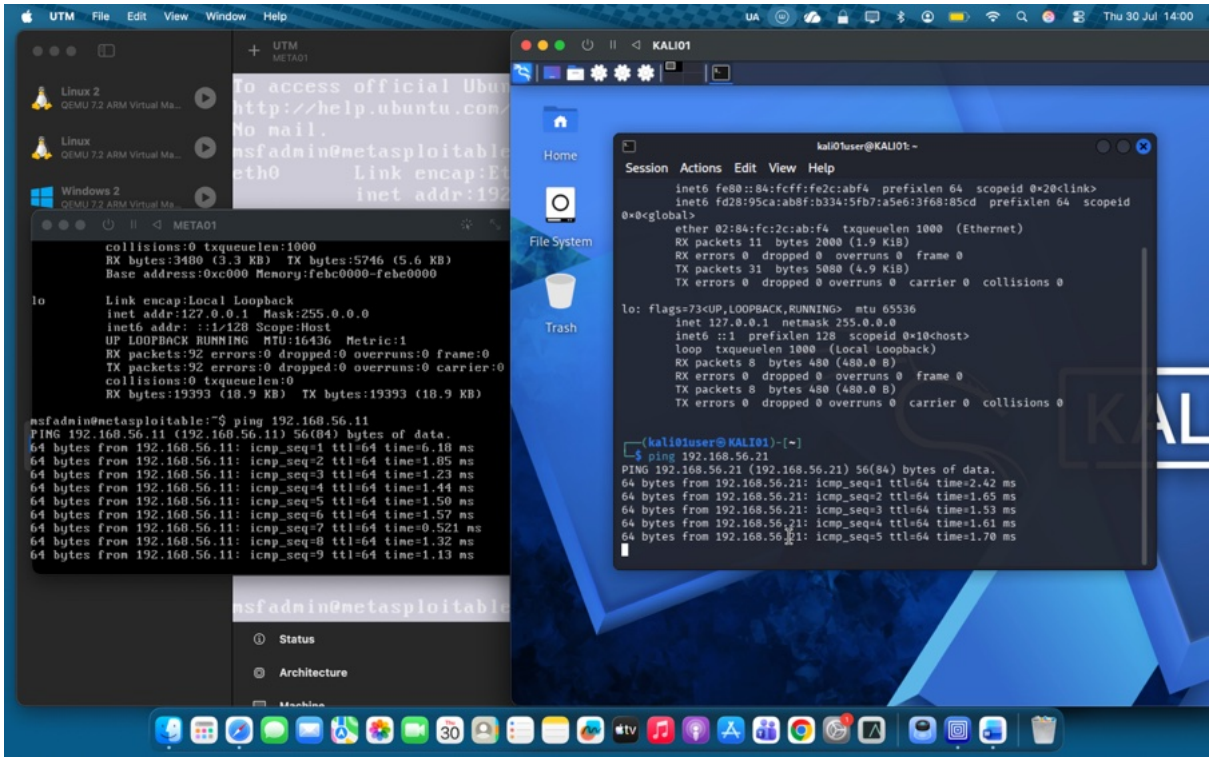
NOTE: So instead I'll be using Shared Network Configuration which is similar to Internal Network in other VM's such as VMware and VirtualBox.




Setting the VM's to Shared Network.

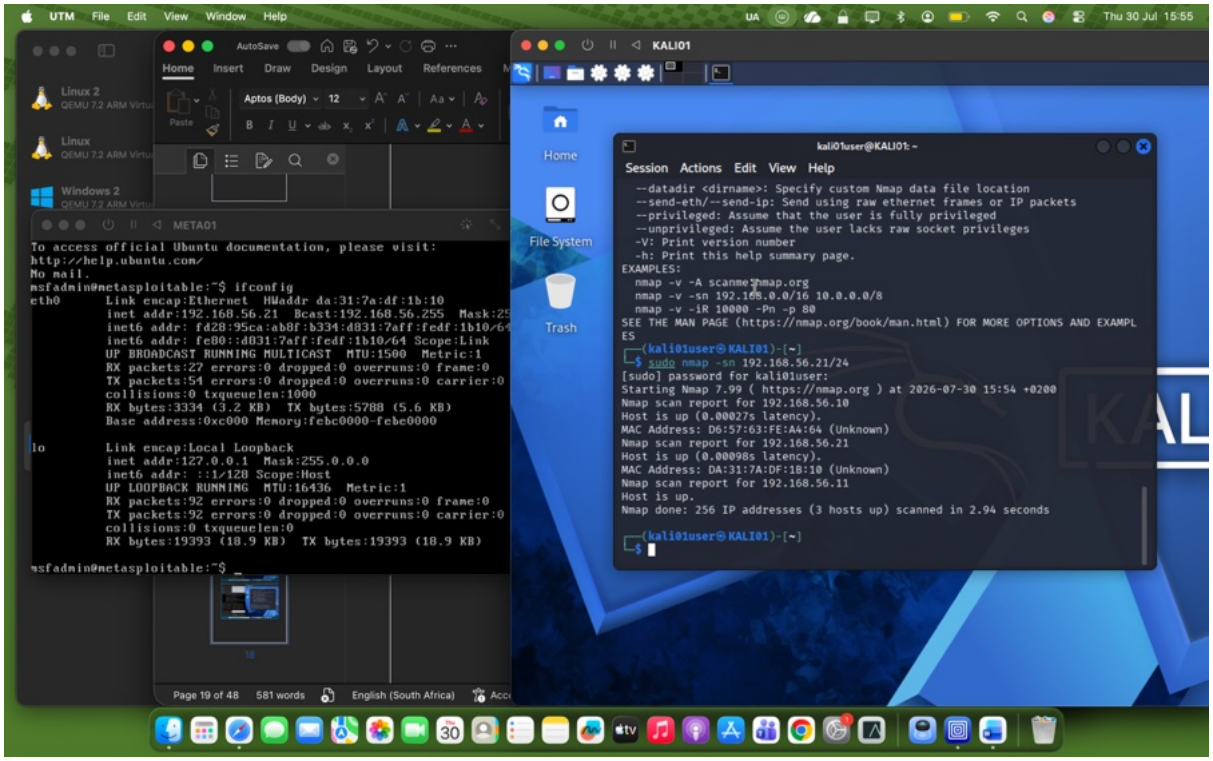



Now both the Virtual Machines Kali Linux and Metasploitable 2 are running at the same time with the preferred IP Addressing Schemes. Tested and displayed using ifconfig.

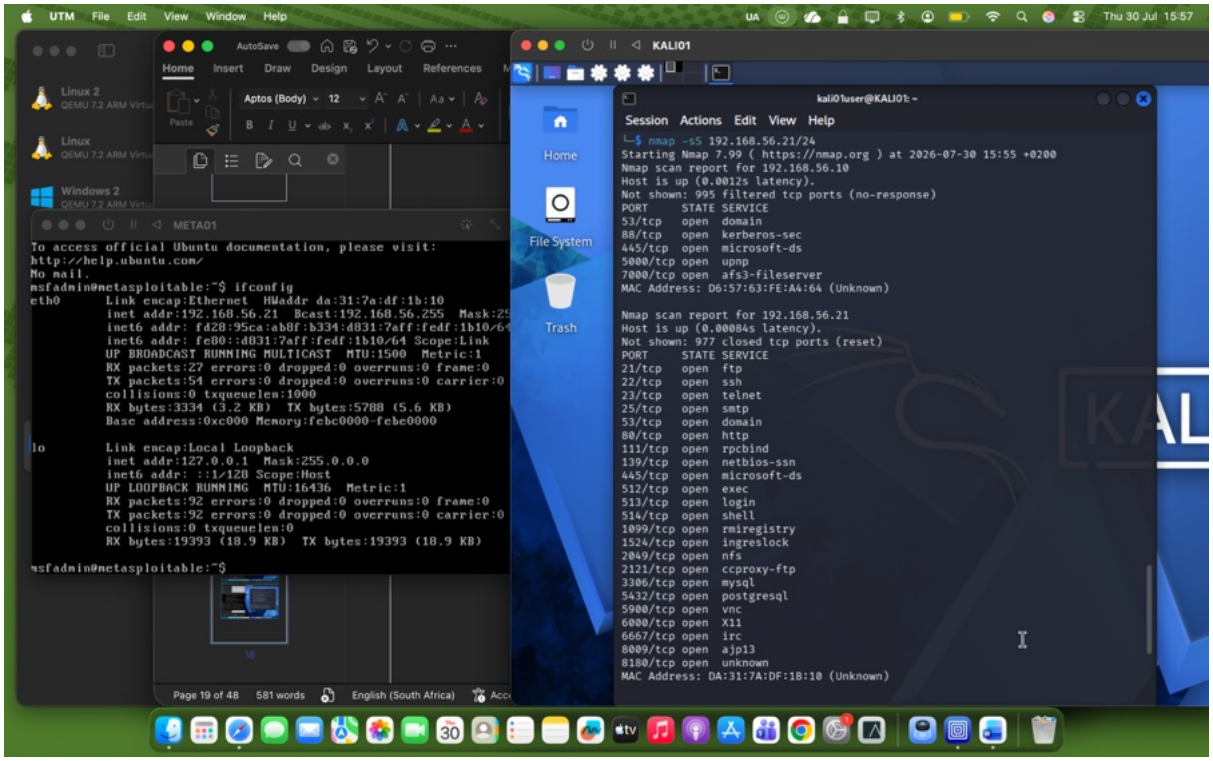



Communication between both VM's Kali Linux and Metasploitable 2 is now possible and Tested using Ping in both machines.

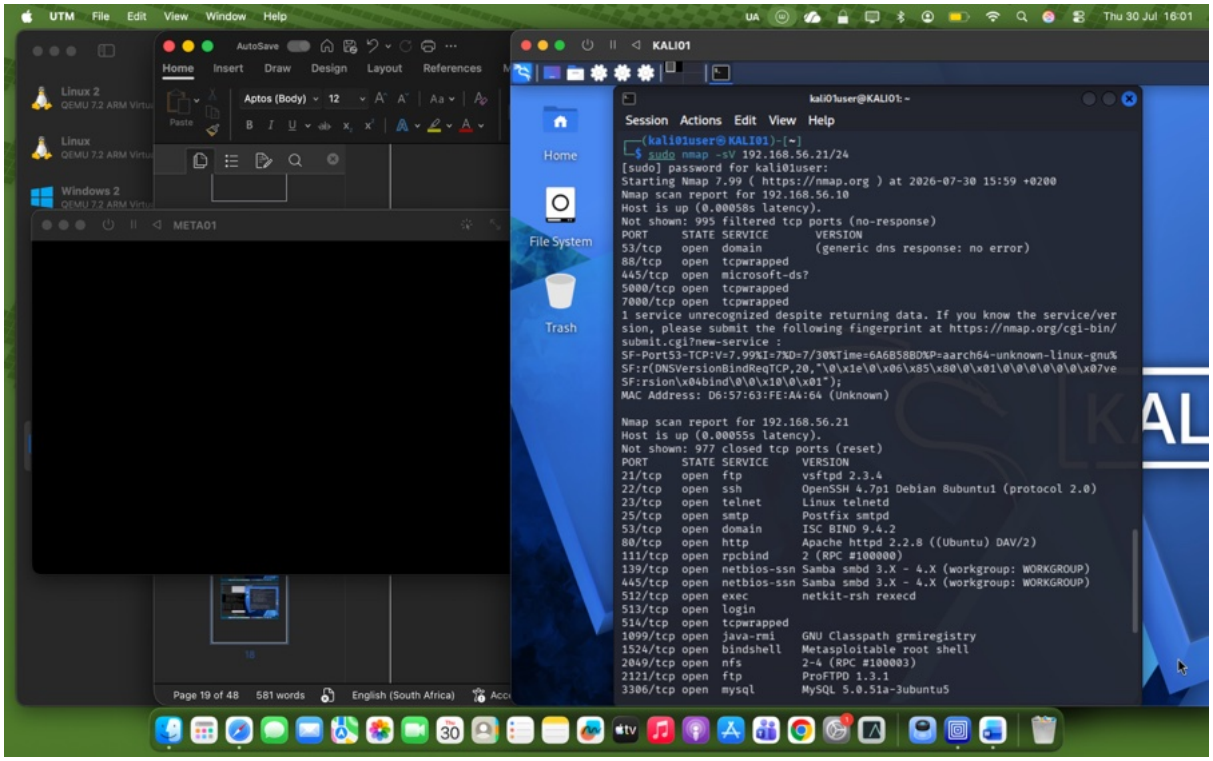
# Question 3

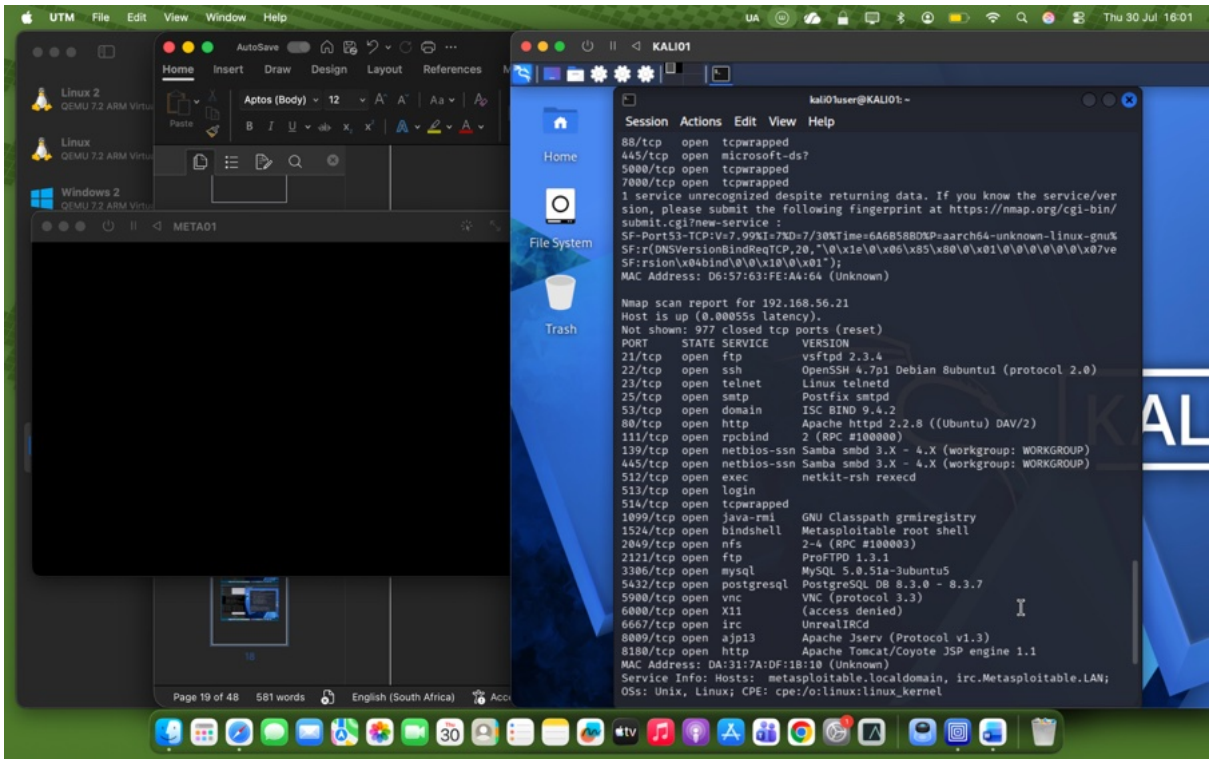



Performing a Host Discovery Scan against Metasploitable 2 using -sn with Kali Linux. To verify target machine is online. Using Nmap.

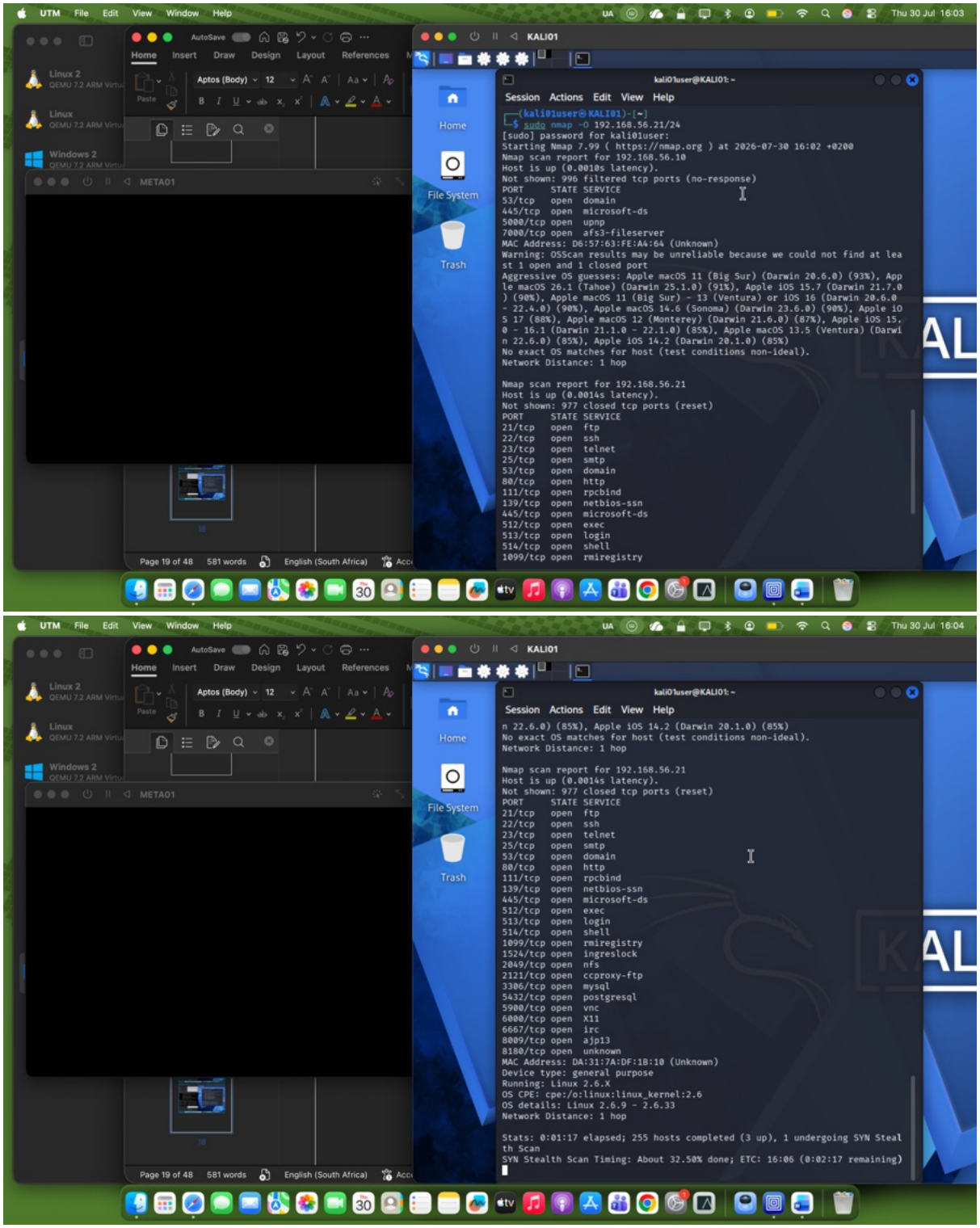


Performing a TCP SYN Scan against Metasploitable 2 using -sS with Kali Linux. To identify open TCP ports. Using Nmap.



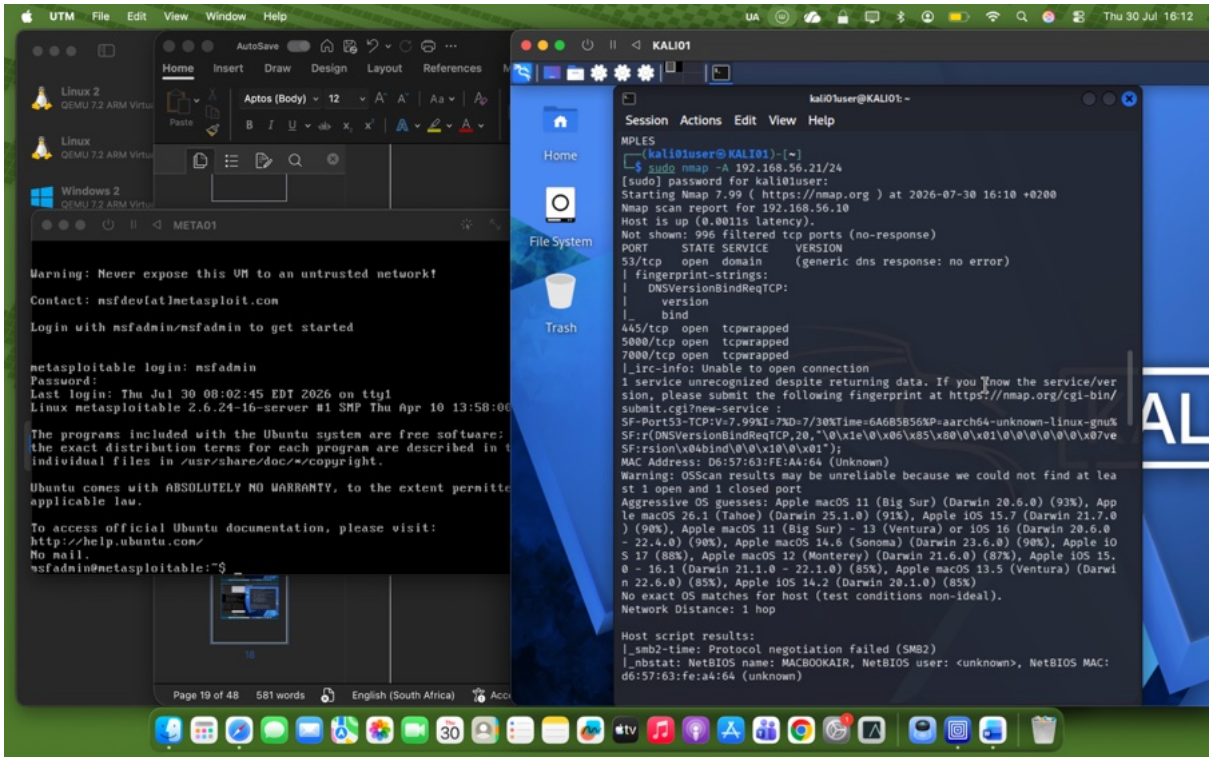

Performing a Service Version Detection Scan against Metasploitable 2 using -sV with Kali Linux. To identify version of the services running or Open Ports. Using Nmap.

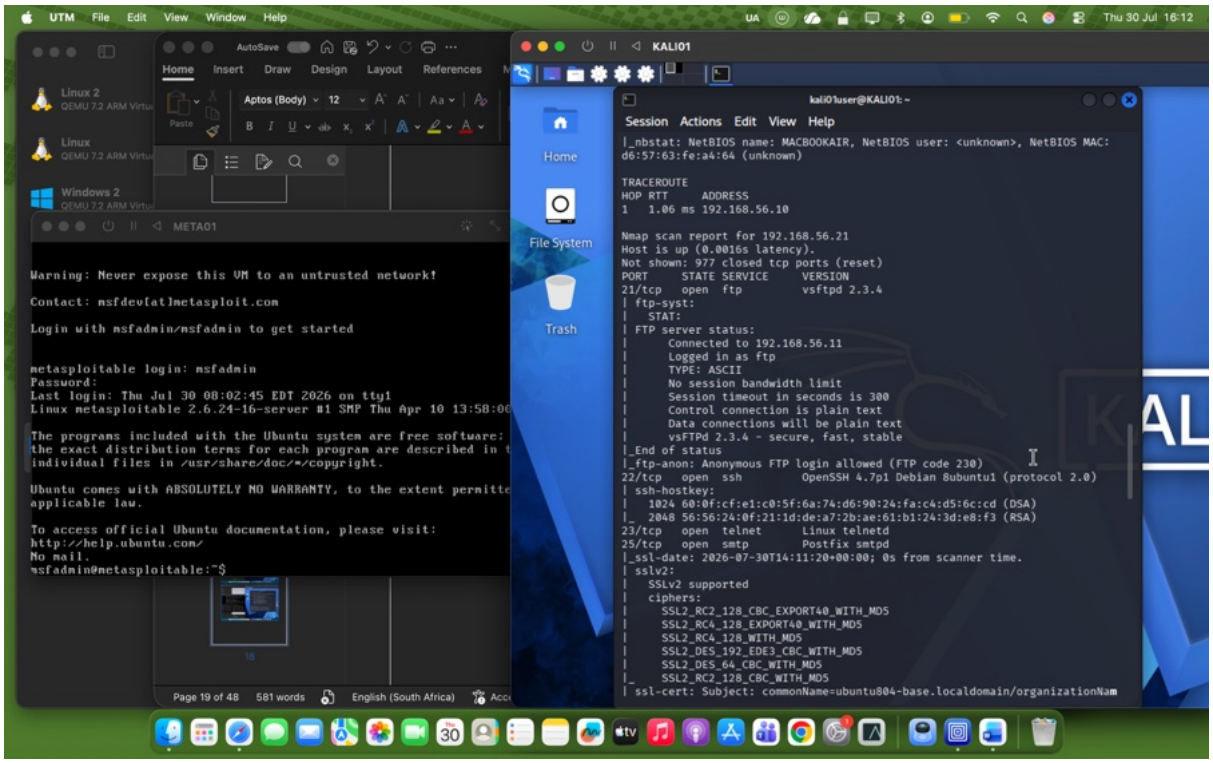


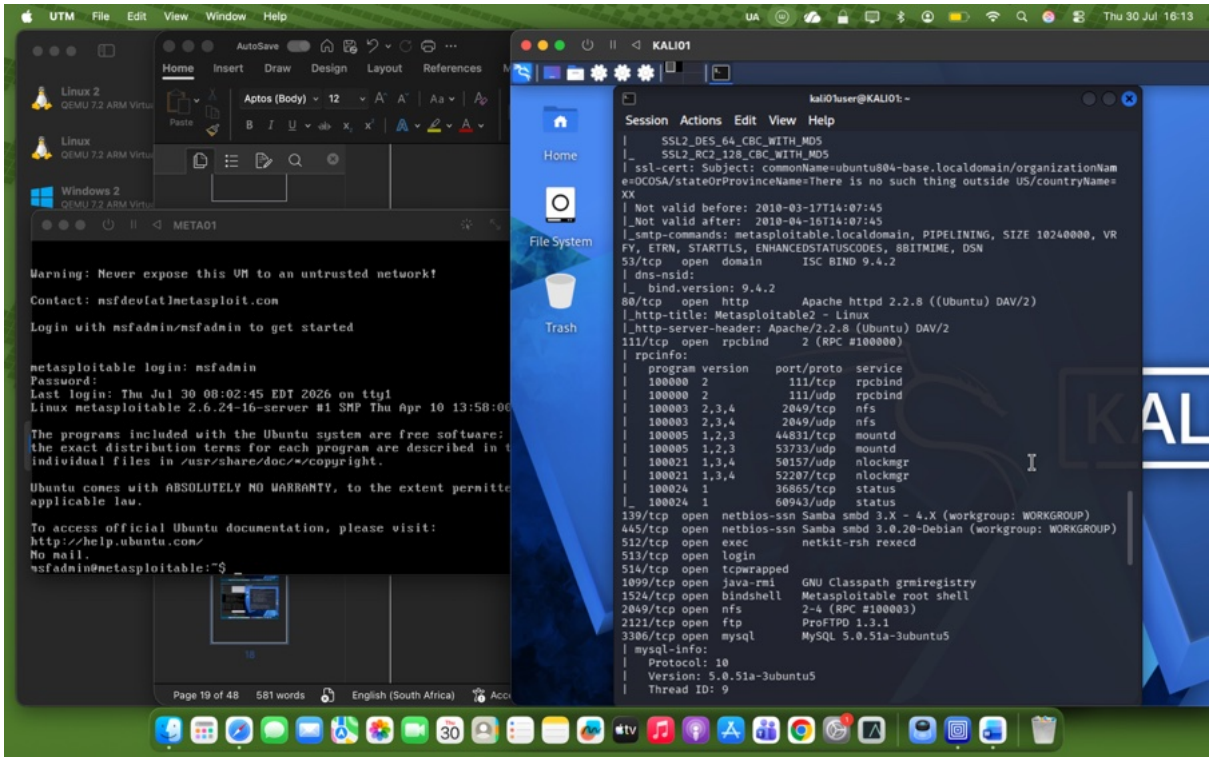


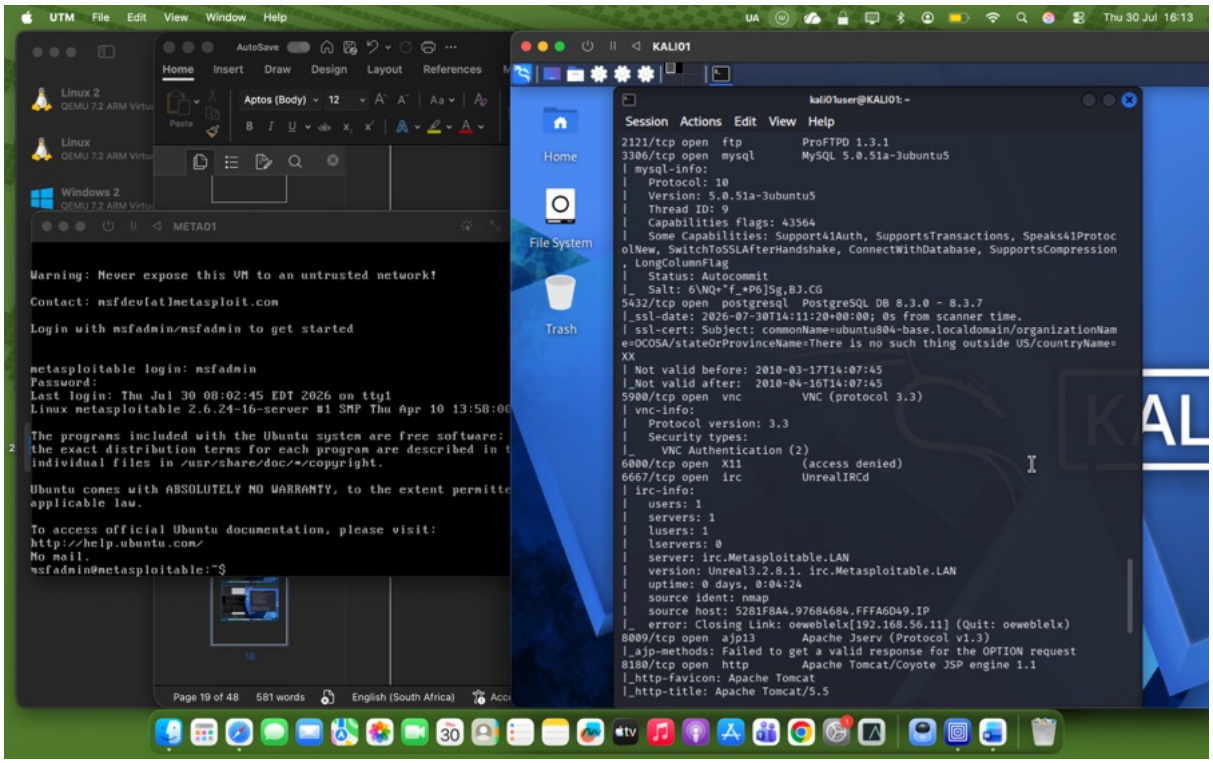


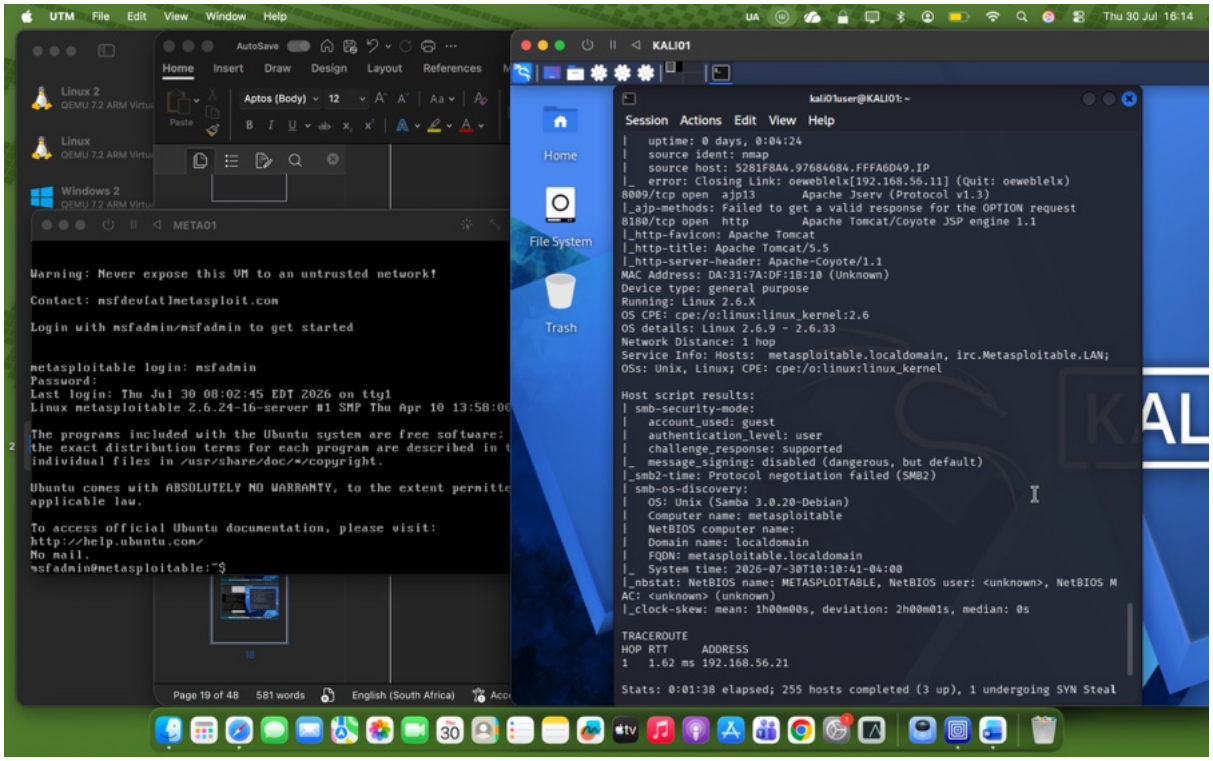
Performing a Operating System Dectection Scan against Metasploitable 2 using -O with Kali Linux. To identify the target Operating System. Using Nmap.


UTM File Edit View Window Help
Thu 30 Jul 16:12
KALI01
META01
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
metasploitable login: msfadmin
Password:
Last login: Thu Jul 30 08:02:45 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in t
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitte
applicable law.
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
kali01user@KALI01: ~
Session Actions Edit View Help
sudo nmap -A 192.168.56.21/24
[sudo] password for kali01user:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 16:10 +0200
Nmap scan report for 192.168.56.10
Host is up (0.0011s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT STATE SERVICE VERSION
53/tcp open domain (generic dns response: no error)
| fingerprint-strings:
| DNSVersionBindReqTCP:
| version
|_ bind
445/tcp open tcpwrapped
5000/tcp open tcpwrapped
7000/tcp open tcpwrapped
|_irc-info: Unable to open connection
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
MAC Address: D6:57:63:FE:A4:64 (Unknown)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Apple macOS 11 (Big Sur) (Darwin 20.6.0) (93%), Apple macOS 26.1 (Tahoe) (Darwin 25.1.0) (91%), Apple iOS 15.7 (Darwin 21.7.0) (90%), Apple macOS 11 (Big Sur) - 13 (Ventura) or iOS 16 (Darwin 20.6.0 - 22.4.0) (90%), Apple macOS 14.6 (Sonoma) (Darwin 23.6.0) (90%), Apple iOS 17 (88%), Apple macOS 12 (Monterey) (Darwin 21.6.0) (87%), Apple iOS 15.0 - 16.1 (Darwin 21.1.0 - 22.1.0) (85%), Apple macOS 13.5 (Ventura) (Darwin 22.6.0) (85%), Apple iOS 14.2 (Darwin 20.1.0) (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: MACBOOKAIR, NetBIOS user: <unknown>, NetBIOS MAC: d6:57:63:fe:a4:64 (unknown)
Page 19 of 48 581 words English (South Africa)


UTM File Edit View Window Help
Thu 30 Jul 16:12
KALI01
META01
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
metasploitable login: msfadmin
Password:
Last login: Thu Jul 30 08:02:45 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in t
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitte
applicable law.
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
kali01user@KALI01: ~
Session Actions Edit View Help
|_nbstat: NetBIOS name: MACBOOKAIR, NetBIOS user: <unknown>, NetBIOS MAC: d6:57:63:fe:a4:64 (unknown)
TRACEROUTE
HOP RTT ADDRESS
1 1.06 ms 192.168.56.10
Nmap scan report for 192.168.56.21
Host is up (0.0016s latency).
Not shown: 977 closed tcp ports (reset)
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 2.3.4
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 192.168.56.11
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
|_ssl-date: 2026-07-30T14:11:20+00:00; 0s from scanner time.
| sslv2:
| SSLv2 supported
| ciphers:
| SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
| SSL2_RC4_128_EXPORT40_WITH_MD5
| SSL2_RC4_128_WITH_MD5
| SSL2_DES_192_EDE3_CBC_WITH_MD5
| SSL2_DES_64_CBC_WITH_MD5
|_ SSL2_RC2_128_CBC_WITH_MD5
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationNam
Page 19 of 48 581 words English (South Africa)


UTM File Edit View Window Help
Thu 30 Jul 16:13
KALI01
META01
kali01user@KALI01: ~
Session Actions Edit View Help
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
metasploitable login: msfadmin
Password:
Last login: Thu Jul 30 08:02:45 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in t
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitte
applicable law.
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
Page 19 of 48 581 words English (South Africa)
Home
File System
Trash


UTM File Edit View Window Help
Thu 30 Jul 16:13
KALI01
META01
kali01user@KALI01: ~
Session Actions Edit View Help
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
metasploitable login: msfadmin
Password:
Last login: Thu Jul 30 08:02:45 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in t
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitte
applicable law.
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
Page 19 of 48 581 words English (South Africa)
Home
File System
Trash




Performing a Aggressive Scan against Metasploitable 2 using -A with Kali Linux. To gather detailed information about target including Operating System, Services, Scripts and Traceroute information. Using Nmap.

## 3.2

| | |
|---|---|
| Target IP Address | 192.168.56.21/24 |
| Open port identified | Tcp: 21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306 5432,5900,6000,6667,8009,8180 |
| Running Service | ftp,ssh,telnet,smtp,domain,http,rpcbind,netbios-ssn,Microsoft-ds,exec,login,shell,rmiregistry,ingreslock,nfs,ccproxy-ftp,mysql,postgresql,vnc,X11,irc,ajp13,unknown |
| Service Version | vsftpd 2.3.4,OpenSSH 4.7p1,Linux telneted,Postfix smtpd,ISC BIND 9.4.2,Apache httpd 2.2.8,2 (RPC #1000),Samba smbd 3.X – 4.X,netkit-rsh rexecd, GNU Classpath grmiregistry,Metasploitable root shell,2-4 (RPC #100003),ProFTPD 1.3.1,MySQL 5.0.51a-3ubuntu5,PostgreSQL DB 8.3.0 VNC(protocol 3.3),UnrealIRCd,Apache Jserv(Protocol v1.3),Apache Tomcat/Coyote JSP engine 1.1 |
| Operating System | Linux 2.6.9 – 2.6.33 |

3.3 Reconnaissance is considered one of the most important phases of penetration testing as it reveals hidden assets and entry point, helping map out the entire digital footprint, helping security professionals uncover forgotten systems, exposing outdated software version, and highlighting configuration mistakes before attacker exploits them by hacking and breaking in.

# Question 4

4.1 The are several vulnerable services running on ports that are insecure including FTP port 21/tcp, Telnet port 23/tcp, Http port 80/tcp, RPCbind port 111/tcp.

4.2 FTP version vsftpd 2.3.4 is a vulnerable service as it contains a malicious implanted backdoor (CVE-2011-2523)

Telnet version linux telneted is a vulnerable service as it contain unencrypted cleartext transmission & configuration flaws.

Http version Apache httpd 2.2.8 is a vulnerable services as it contains outdated software, source code exposure and Dos leaks.

And RCPbind version 2 (RPC #100000) is a vulnerable services as it contains excessive information disclosure & amplification vectors.

4.3 The vulnerabilities could a have affected Eduvos if exploited, by granting attackers immediate, unauthenticated root-level control with (ftp) vsftpd

2.3.4 backdoor allowing bypassed security controls stealing sensitive students records, financial information and research data.

Attacker could leverage unencrypted protocols like (telnet) Linux telned to harvest administrative credentials.

And exploit outdated (http) Apache httpd configuration to access restricted web directories

Or use RCPbind to map out and crash the core network infrastructure through resource-exhaustion attacks.

4.4 Weakness could be abused by an attacker by directly targeting structural flaws, unencrypted traffic or code backdoor presences within each service.

Using FTP version vsftpd 2.3.4 to simply enter a username containing a smiley face [:)], triggering a malicious code sequence opening unauthenticated root command shell on an alternate port.

Using Telnet version Linux telneted to sniff network packets to intercept and harvest administrative credentials transmitted entirely in plain text.

Using Http version Apache httpd to abuse outdated configurations or unsafe WebDAV methods to upload a malicious web shell, gaining remote code execution capabilities.

Using rpcbind to map out internal network infrastructure or flood it with resource-heavy packets to crash the entire system.

4.5 Suggested appropriate security controls or best practices that would reduce or eliminate the vulnerability would include disabling unencrypted, legacy, unnecessary services like telnet, rcpbind and replacing them with modern, encrypted protocols like SSH and SFTP with strongly enforced authentication.

And securing web operation by upgrading HTTP - Apache httpd and FTP – vsftpd 2.3.4 to their lasted stable. Patched software version, to HTTPS and SFTP, erasing known code-execution flaws and backdoor exploits.

And implementing Strong Network access control through host-based firewalls and network

segmentation ensuring blockage to unauthorised actors enforcing strong authentication.

## 4.6

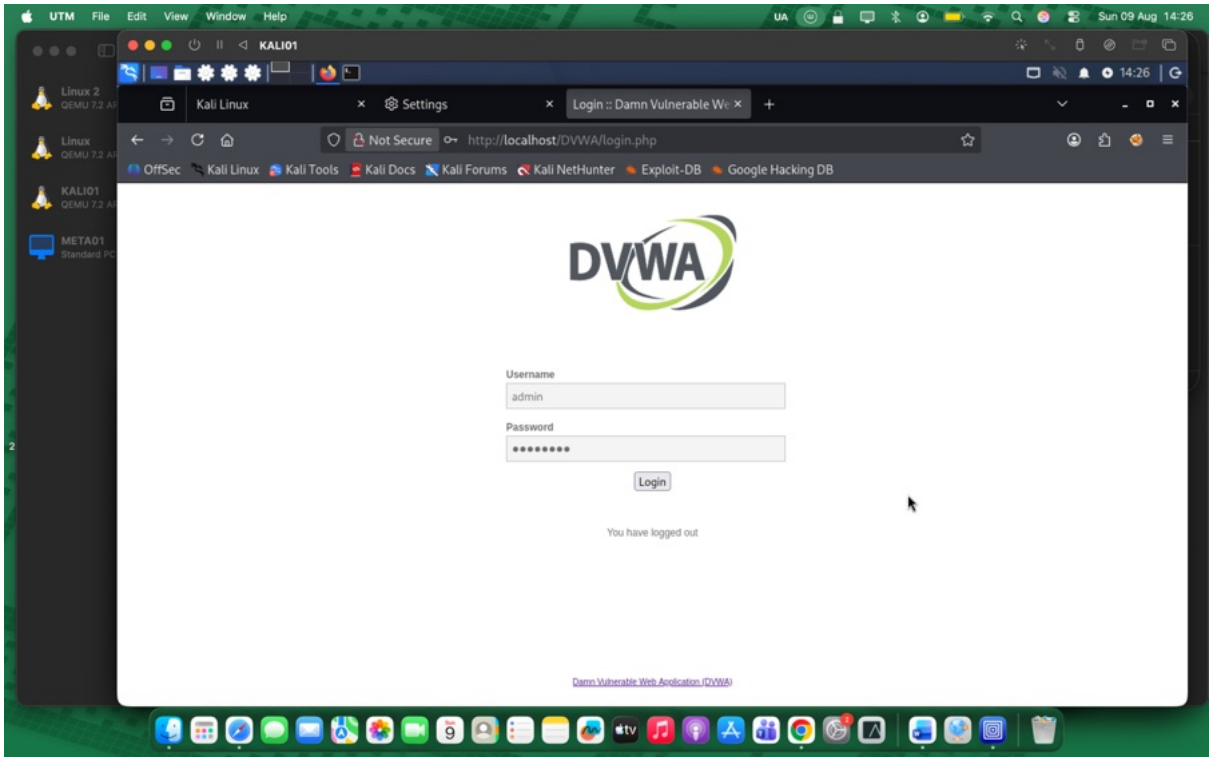
- Identifying vulnerabilities is a critical phase of pentesting as it maps the attack surface locating weak spots like open ports, outdated software, and bad configuration before an attacker does. Providing a foundation for exploitation giving tester the exact targets needed to simulate real-world attacks safely. And allows team to prioritize security fixes helping companies fix most dangerous security gabs first. Which all reduces risk by stopping hackers from using hidden flaws to stored data, Test defence to show it current security tools can spot or block a threat and Saves money as early flaw fixing cost less than recovering from a real data breach.
- Vulnerability assessment helps organisation such as Eduvos to improve their overall security posture by finding weak spots scanning spot missing software updates, open ports, and bad

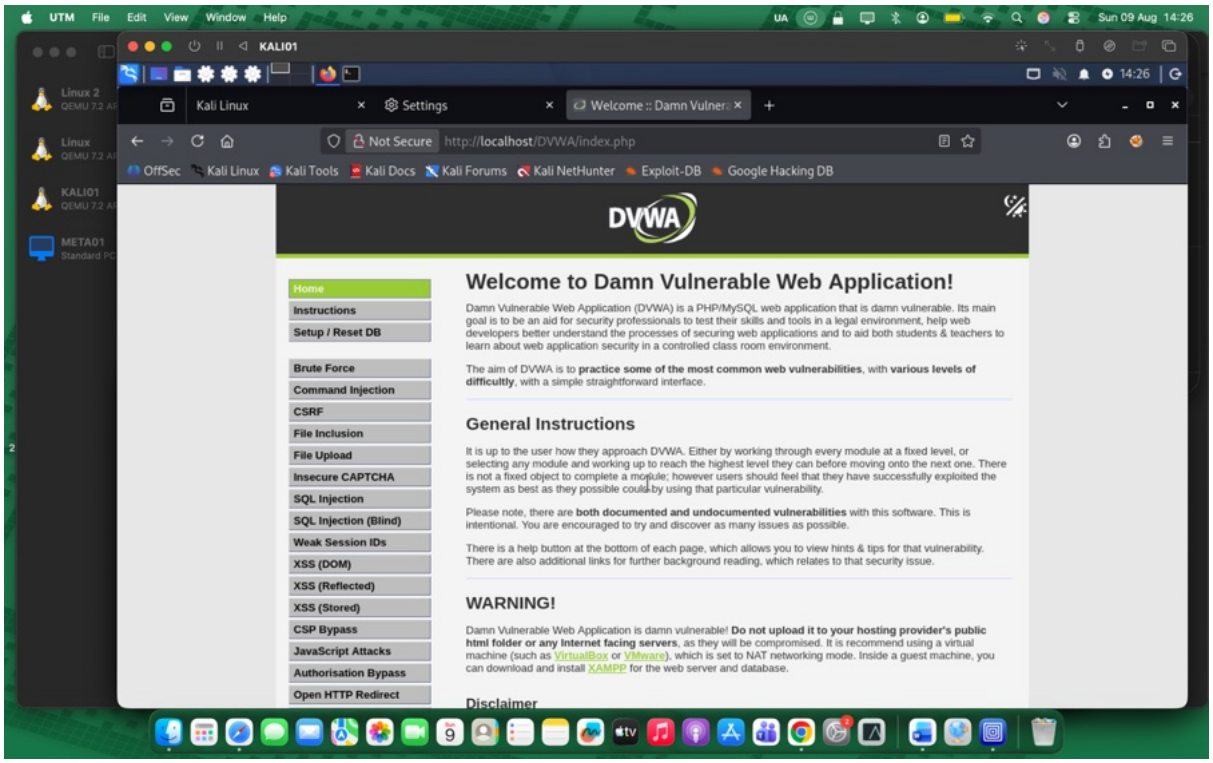
system setting across student portal and staff networks. Prioritizing Rules as team see flaws which pose the biggest danger so they can fix critical issues first. Protecting data by securing data base and Web app stops data leaks and keeps private user records safe. Meeting Rules as regular checks help intuition follow data privacy laws like South Africa's POPIA.

- Vulnerability should be prioritised and remediated before deploying new systems into production environment to prevent data breaks, avoid costly fixes and ensure system stability. As old flaws act as open door for hackers to steal data or break the system making it a priority to stop active attacks. As single early breach ruins company's name and scares customers another priority and remediated to protect user trust. And fixing flaw early keeping bad issues from spreading to other connects computers saving money and time and enabling easier updates.

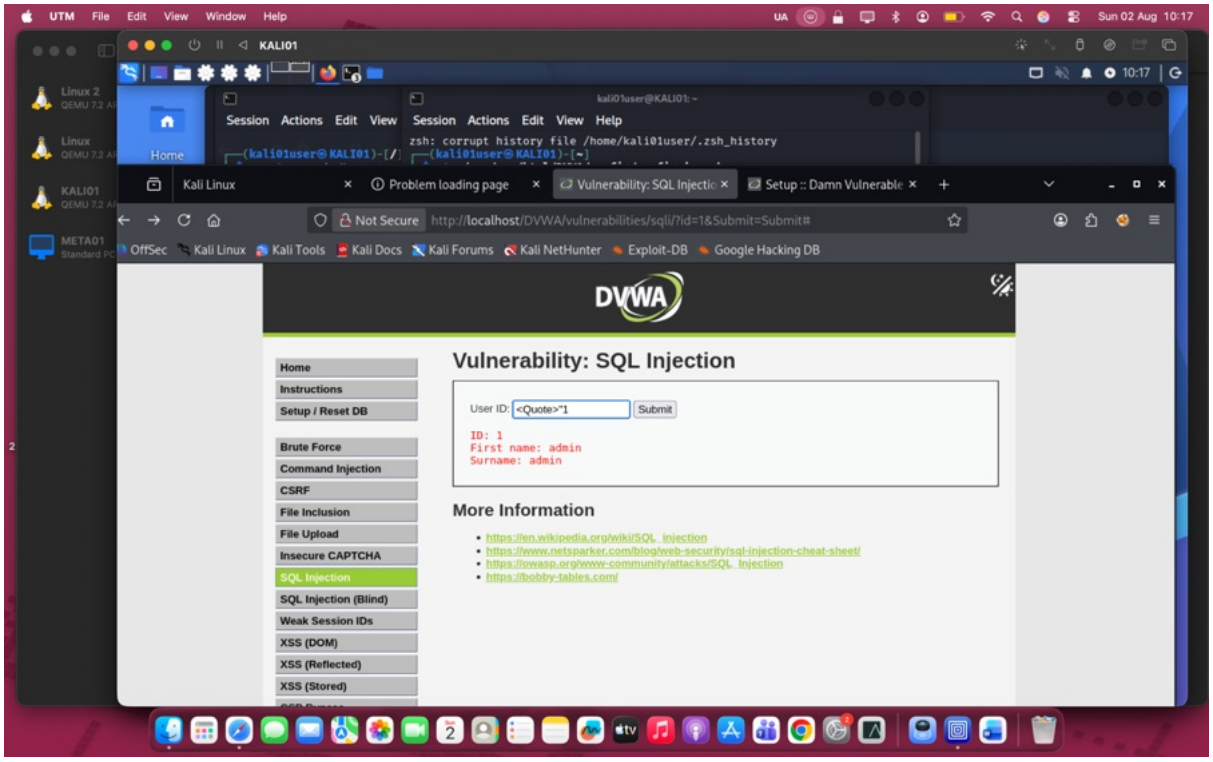
# Question 5

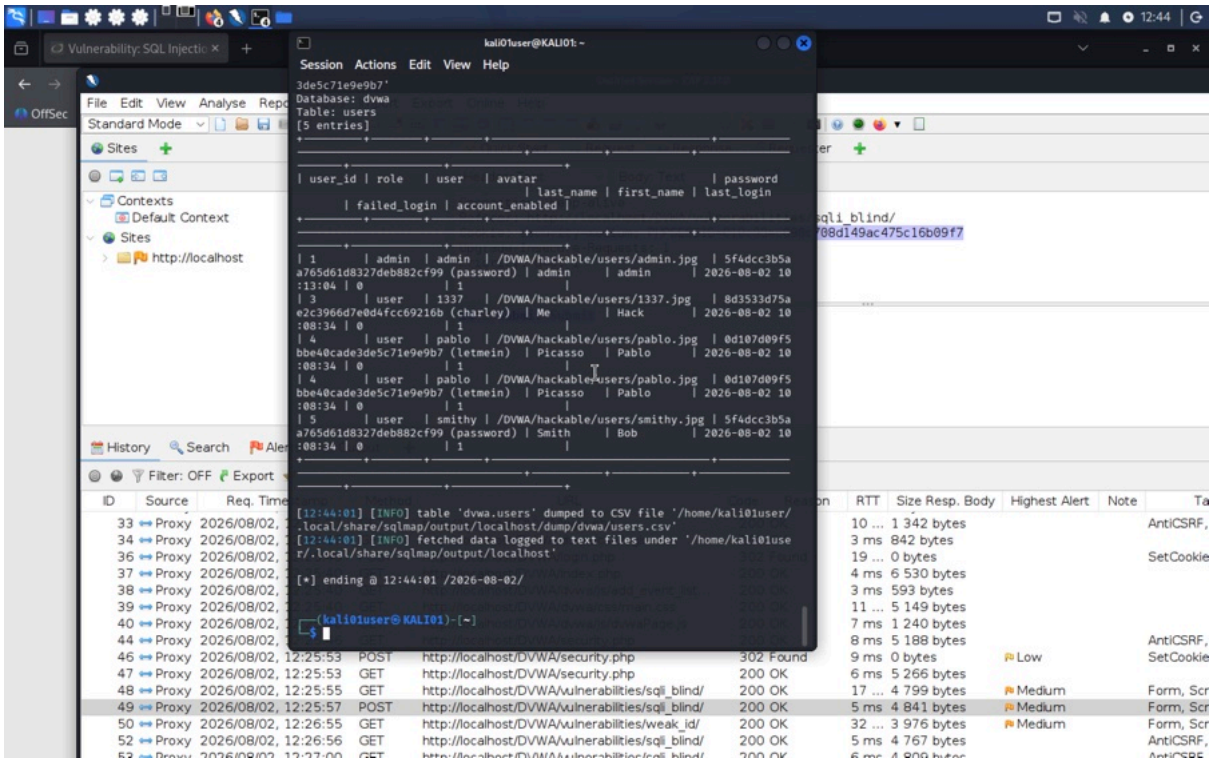
## 5.1



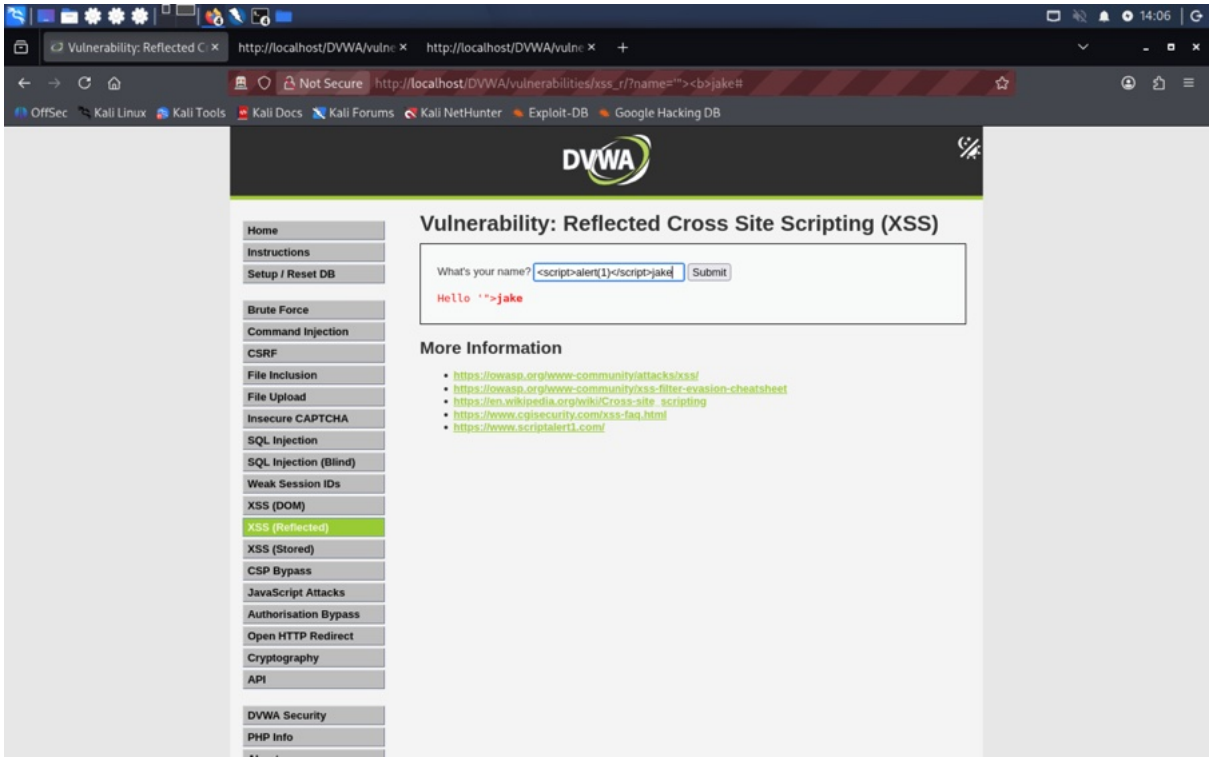



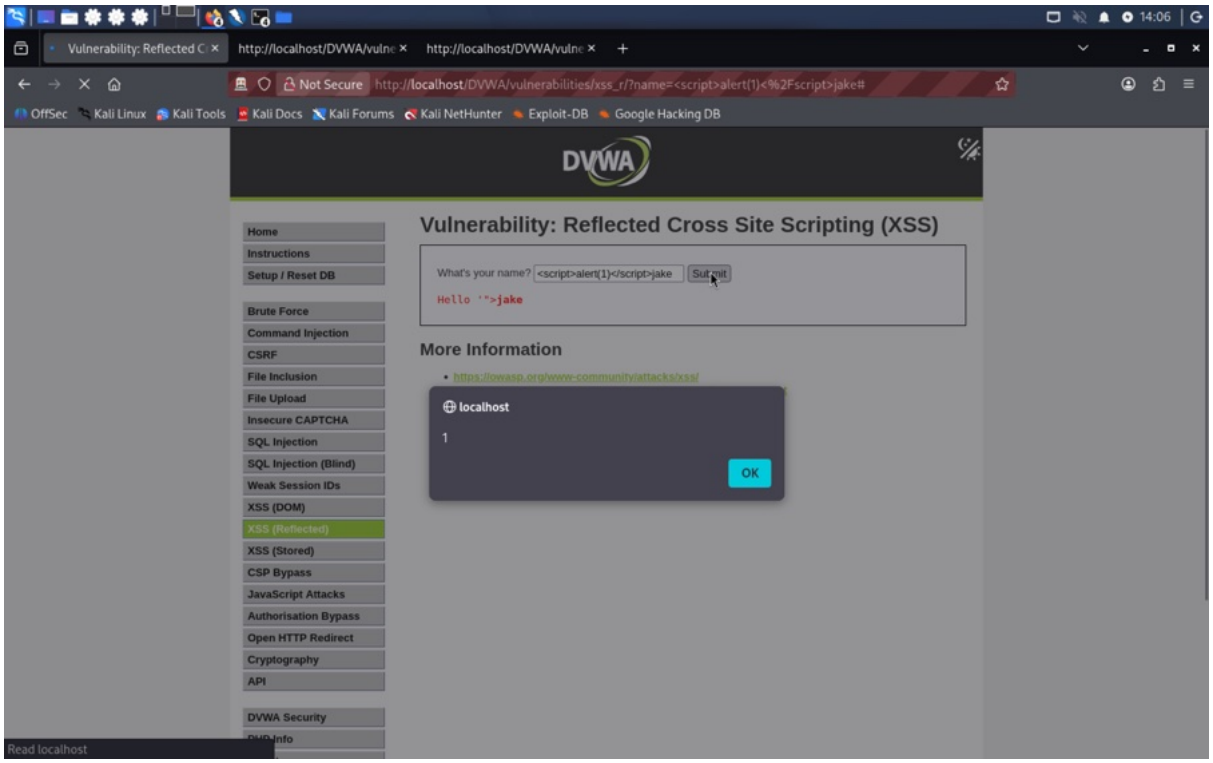

Successful Login to DVWA Using “admin” and “Password”.

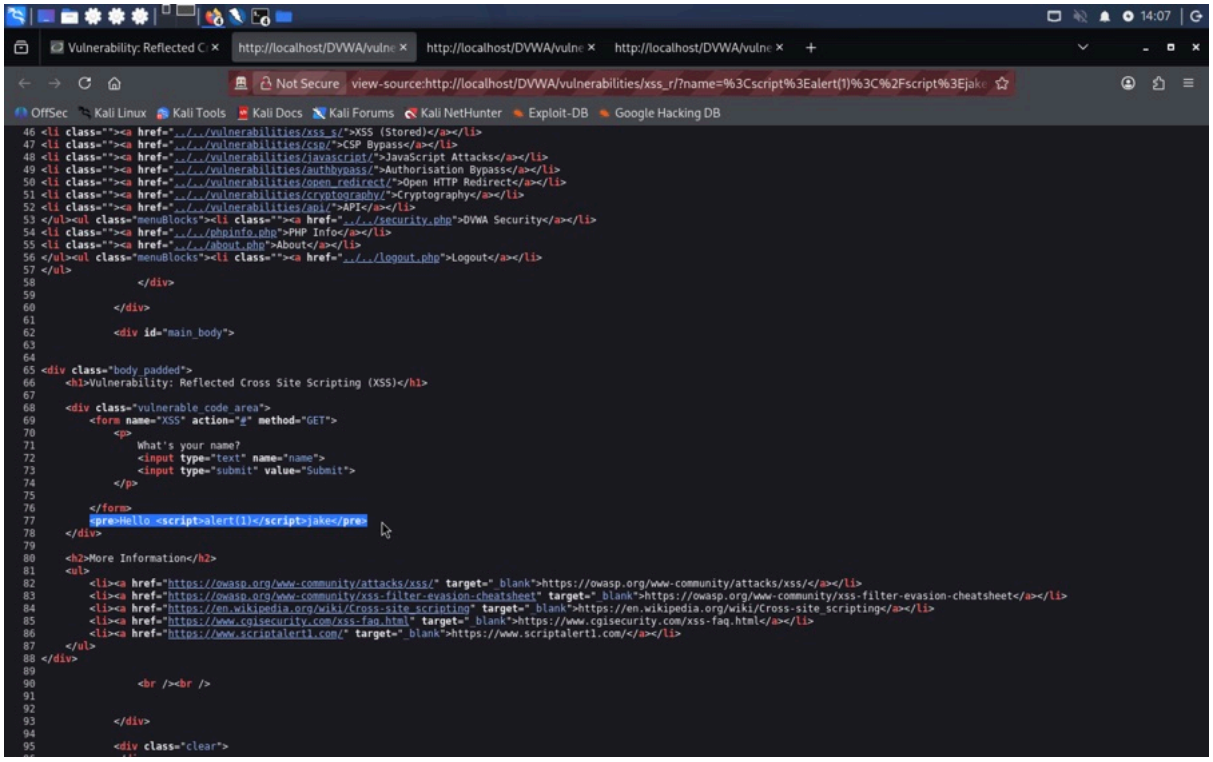



Demonstration of SQL Injection Vulnerability with Zaproxy and SQL-Map. Using URL, Cookie and Data ID.

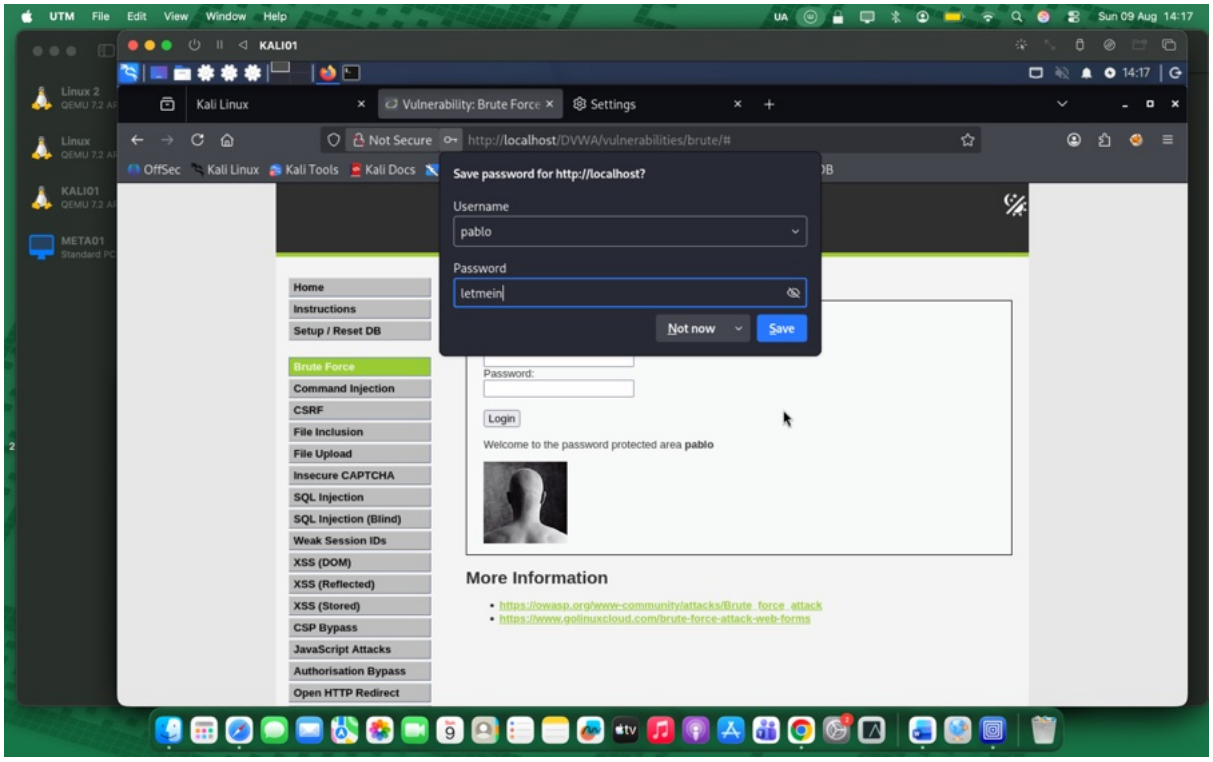

Vulnerability: Reflected C
http://localhost/DVWA/vulne
http://localhost/DVWA/vulne
Not Secure
http://localhost/DVWA/vulnerabilities/xss_r/?name="><b>jake#
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
API
DVWA Security
PHP Info
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name? <script>alert(1)</script>jake
Submit
Hello '">jake
More Information
https://owasp.org/www-community/attacks/xss/
https://owasp.org/www-community/xss-filter-evasion-cheatsheet
https://en.wikipedia.org/wiki/Cross-site_scripting
https://www.cgisecurity.com/xss-faq.html
https://www.scriptalert1.com/


Vulnerability: Reflected C
http://localhost/DVWA/vulne
http://localhost/DVWA/vulne
Not Secure
http://localhost/DVWA/vulnerabilities/xss_r/?name=<script>alert(1)<%2Fscript>jake#
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
API
DVWA Security
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name? <script>alert(1)</script>jake
Submit
Hello '">jake
More Information
https://owasp.org/www-community/attacks/xss/
localhost
1
OK
Read localhost

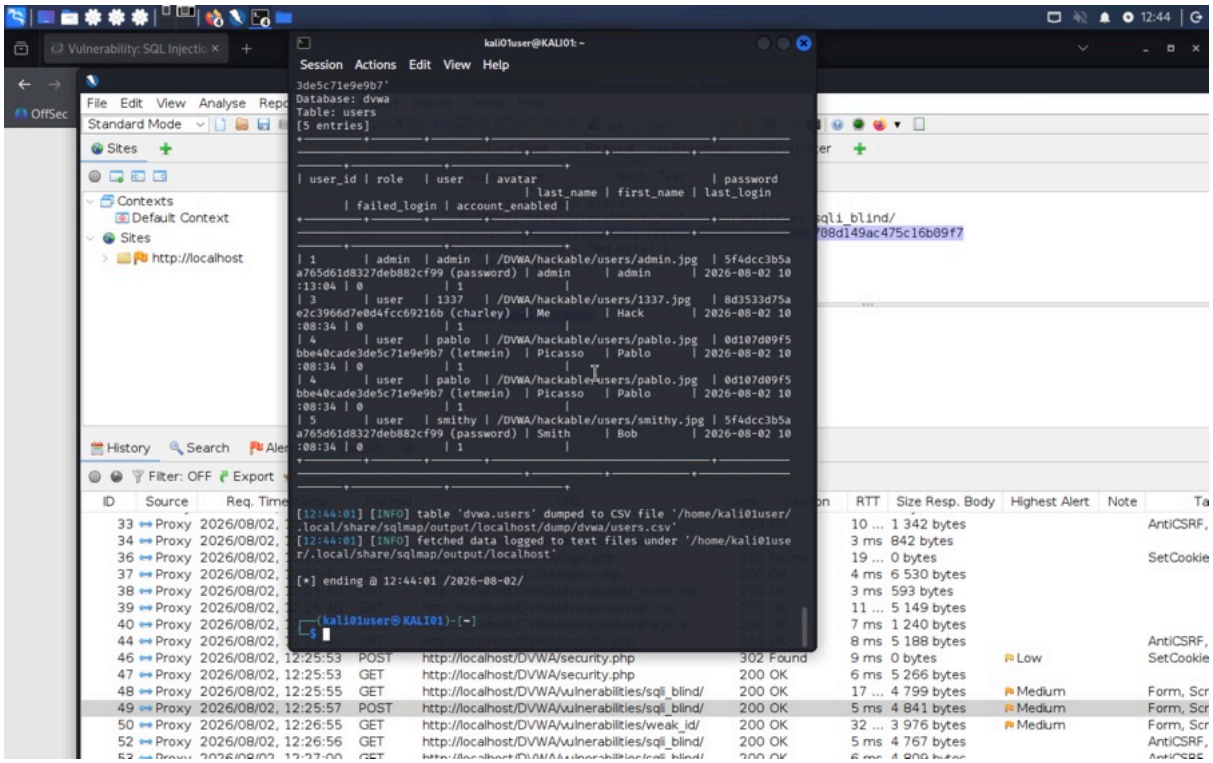



Demonstration of Cross-site Scripting Vulnerability with <scrip>alert(1)</script>jake.

NOTE: after many attempts and research I came to a conclusion that Hydra and Burp Suite without the paid Pro version does not function well with Dictionary Brute Force Attacks against DVWA. Although I was able to spot Weak Authentication and access the Passwords with Zaproxy and SQL-Map.




Demonstration that the passwords obtained from sqlmap are affective.




Demonstration of Weak Authentication/Passwords Vulnerability with Zaproxy and SQL-Map.

5.2 Vulnerabilities such as database SQL, Cross-site scripting(XSS) and weak authentication or weak passwords could affect Eduvos Students Registration System.

With SQL letting hackers run malicious database commands exposing privilege student records, alter grades, leak login credentials, or let attackers take complete control of the Eduvos server and database.

With Cross-site scripting allowing attackers to steal session cookies hijack administrator account, alter registration data, or launch phishing attack against student and staff, compromising the entire Eduvos database

And weak passwords letting hackers break into a student registration system easily allowing attackers to steal personal data, change grades, or block access to classes, harming students, ruining Eduvos trust and causing legal trouble.

5.3 Mitigation strategies can be used for each of these vulnerability such as Prepared statements for SQL injections, Context-aware output encoding for

Cross-Site scripting (XSS) and Strong hashing with multi-factor authentication for weak passwords.

As using Prepared Statements and Parameterised Queries helps so data cannot change query and apply least privilege.

As Context Aware Output encoding implement a strict Content Security Policy(CSP) to block unauthorized scripts.

As Hashing passwords using modern, slow algorithms like Argon2id or bcrypt with unique salts and enforcing Multi-Factor Authentication for all user accounts setting strong minimum length and complexity rules while blocking known breached passwords.